TRƯỜNG ĐẠI HỌC GIAO THÔNG VẬN TẢI
KHOA CÔNG NGHỆ THÔNG TIN

---------- ✦ ----------



BÀI TẬP LỚN
LẬP TRÌNH WEB
ĐỀ TÀI: QUẢN LÍ THƯ VIỆN

Giảng viên hướng dẫn: **Lại Mạnh Dũng**
Sinh viên thực hiện: **Tô Minh Trường**
Lớp: **CNTT2**
Khoá: **K63**

Hà Nội, tháng 10 năm 2026

MỤC LỤC

CHƯƠNG 1. TỔNG QUAN VỀ ĐỀ TÀI....1
1.1. Mô tả về hệ thống, các nghiệp vụ cơ bản....1
Giới thiệu đề tài....1
Mô hình hoạt động....1
Các nghiệp vụ cơ bản....2
Quy tắc nghiệp vụ chính....2
Quy trình phát triển phần mềm....3
Công nghệ và công cụ sử dụng....3
1.2. Khảo sát, phân tích yêu cầu để xác định các chức năng cho các lớp người dùng4
Khảo sát....4
Các lớp người dùng....4
Chức năng cho từng lớp người dùng....5
Phân quyền....6
Yêu cầu phi chức năng....6
Đối chiếu yêu cầu của đề bài....6
CHƯƠNG 2. THIẾT KẾ....8
2.1. Vẽ use-case diagram....8
Đặc tả một số use-case chính....9
2.2. Thiết kế cơ sở dữ liệu: ERD, mô tả về dữ liệu, các ràng buộc....11
Sơ đồ quan hệ thực thể (ERD)....11
Mô tả dữ liệu....14
Các ràng buộc....18
Quy ước mã tự sinh....19
2.3. Vẽ sitemap và wireframe bằng công cụ draw.io....19
Sitemap....19
Wireframe....20
Thiết kế giao diện (template tùy biến)....24
CHƯƠNG 3. TRIỂN KHAI....25
3.1. Lập trình xây dựng các chức năng cho hệ thống....25
Môi trường phát triển....25
Kiến trúc tổng thể....26
Phân trang (Paging)....26
Lọc và tìm kiếm (Filtering)....26
Annotation....27
Session....27
Cookie....27
REST API....27
AJAX....28
Bảo mật (Security)....28
Quốc tế hóa (Internationalization)....28
Kiểm tra điều kiện mượn....29
Tính tiền khi trả sách....29
Chống mượn trùng và kiểm soát đồng thời....29
Bán thẻ, cọc và hoàn cọc....29
3.2. Mô tả kết quả đạt được bằng cách dán các hình ảnh và giải thích về từng chức năng trong hệ thống....29

Trang chủ và tra cứu sách (công khai).....29
Đăng ký và đăng nhập.....32
Khu vực khách hàng.....33
Bảng điều khiển và quản lý kho sách (Admin).....35
Gói thẻ và khách hàng.....37
Mượn, trả, gia hạn.....39
Sổ giao dịch và báo cáo.....41
REST API và bảo mật.....44
CHƯƠNG 4. KIỂM THỬ.....46
4.1. Mục tiêu phát hiện lỗi trong quá trình xây dựng hệ thống.....46
Môi trường và dữ liệu kiểm thử.....46
4.2. Cách thức: xây dựng danh mục các test case.....46
Danh mục test case.....46
Các test case tiêu biểu.....47
4.3. Kết quả test pass/fail, đề xuất và mô tả quá trình fix lỗi.....48
Kết quả tổng hợp.....48
Lỗi phát hiện trong đợt kiểm thử và đề xuất sửa.....48
Test case chưa thực hiện.....49
Lỗi gặp trong quá trình phát triển và cách khắc phục.....49
Nhận xét kết quả kiểm thử.....50
CHƯƠNG 5. KẾT LUẬN.....51
5.1. Kết quả đạt được.....51
Hạn chế còn tồn tại.....51
5.2. Bài học được rút ra.....51
5.3. Đề xuất phương hướng phát triển.....52
Tài liệu tham khảo.....53

CHƯƠNG 1. TỔNG QUAN VỀ ĐỀ TÀI

1.1. Mô tả về hệ thống, các nghiệp vụ cơ bản

Giới thiệu đề tài

Thư viện là nơi lưu trữ và cho mượn sách. Khi số đầu sách, số bản sách và số người mượn tăng lên, việc ghi sổ bằng tay hoặc bảng tính nhanh chóng gặp khó khăn: khó biết một cuốn sách đang ở đâu, ai đang giữ, khi nào phải trả, mức phạt bao nhiêu, và cuối tháng thu được bao nhiêu tiền. Đề tài **"Xây dựng website quản lý thư viện"** giải quyết các vấn đề đó bằng một hệ thống web, vừa phục vụ nhân viên làm việc tại quầy, vừa cho khách tra cứu và theo dõi việc mượn sách của chính mình.

Hệ thống được xây dựng bằng **ASP.NET Core MVC** (.NET 10), cơ sở dữ liệu **SQL Server**, giao diện **Bootstrap 5** kết hợp **jQuery/AJAX**. Bài tập lớn do một sinh viên thực hiện toàn bộ các giai đoạn: phân tích, thiết kế, lập trình, kiểm thử và viết tài liệu.

Mục tiêu của đề tài:

- Xây dựng hệ thống web có **hai khu vực chức năng tách biệt** cho các lớp người dùng khác nhau: khu quản trị cho người vận hành thư viện và khu khách hàng.
- Số hóa trọn vẹn nghiệp vụ tại quầy: quản lý kho sách, bán thẻ thành viên, **mượn, trả, gia hạn**, thu tiền (phí thẻ, tiền cọc, phí thuê, tiền phạt, tiền đền) và báo cáo.
- Cho khách tra cứu sách công khai, xem tình trạng còn sách, và tự theo dõi thẻ, sách đang mượn, lịch sử, khoản nợ; gia hạn trực tuyến.
- Vận dụng các nội dung học phần Lập trình web: Responsive, Paging, Filtering, AJAX, CRUD, Session, Cookie, Annotation, REST API, bảo mật và quốc tế hóa.

Phạm vi của hệ thống:

Bảng 1.1. Phạm vi của hệ thống

Có thực hiện	Không thực hiện (hướng phát triển)
Một thư viện, một cơ sở, chỉ sách in. Hai vai trò: Admin (người vận hành) và User (khách hàng); khách vãng lai xem được phần công khai. Bán thẻ, cọc, mượn, trả, gia hạn, phạt, đền, thu nợ, hủy giao dịch, báo cáo. Tra cứu công khai, tài khoản khách hàng, REST API, AJAX, tiếng Việt và tiếng Anh.	Đặt giữ sách trước, thanh toán trực tuyến, gửi email/SMS nhắc hạn. Tích hợp thiết bị quét mã vạch, nhiều chi nhánh, sách điện tử. Phân quyền chi tiết giữa chủ và nhân viên, nhật ký thao tác. Dịch toàn bộ khu quản trị sang tiếng Anh.

Mô hình hoạt động

Hệ thống mô phỏng một thư viện tư nhân hoặc cộng đồng hoạt động theo kiểu **cửa hàng**: một cơ sở, quy mô giả định khoảng 5.000 đầu sách (khoảng 8.000 bản), 1.000 thành viên và 3 nhân viên. Khách có thể **đọc tại chỗ** mà không cần thẻ, hoặc mua **thẻ thành viên** để **mượn sách về nhà**. Toàn bộ vận hành (nhập sách, bán thẻ, mượn trả, thu tiền, báo cáo) thực hiện trên website.

Mỗi đầu sách (một tên sách) có nhiều **bản sao** vật lý, mỗi bản có mã vạch riêng, vị trí kệ và trạng thái riêng. Khách mua một trong các **gói thẻ**; mỗi gói quy định giá, thời hạn, tiền cọc, số sách mượn tối đa, số ngày mượn và số lần gia hạn. Một số sách mới hoặc được ưa chuộng có **phí thuê**. Trả trễ bị **phạt**, làm mất hoặc hỏng sách phải **đền**.

Các nghiệp vụ cơ bản

Bảng 1.2. Các nhóm nghiệp vụ

Nhóm nghiệp vụ	Nội dung
Quản lý kho sách	Quản lý tác giả, thể loại, đầu sách (kèm ảnh bìa, phí thuê, giá đền); nhập bản sao với mã vạch tự sinh; đổi trạng thái bản sao (sẵn sàng, đang mượn, mất, hỏng, thanh lý).
Quản lý thẻ và khách hàng	Quản lý gói thẻ; tạo hồ sơ khách tại quầy; bán và gia hạn thẻ, thu tiền cọc; khóa hoặc mở khóa khách; hoàn cọc khi trả thẻ.
Mượn, trả, gia hạn	Lập phiếu mượn bằng mã vạch với kiểm tra điều kiện tự động; trả sách có tính phí thuê, phạt trễ, tiền đền; gia hạn; thu nợ; in phiếu.
Thu tiền	Sổ giao dịch mọi khoản thu, lọc và xuất CSV; hủy giao dịch có lý do; phân biệt doanh thu với tiền cọc (tiền giữ hộ).
Báo cáo	Doanh thu theo ngày hoặc tháng; sách quá hạn; sách mượn nhiều và sách tồn lâu; thẻ sắp hết hạn; thống kê kho sách.
Tra cứu và tự phục vụ	Khách tra cứu sách (tìm, lọc, sắp xếp), xem bảng giá; sau khi đăng nhập xem thẻ, sách đang mượn, lịch sử, khoản nợ và gia hạn.

Quy tắc nghiệp vụ chính

Bảng 1.3. Quy tắc nghiệp vụ

Quy tắc	Nội dung
Điều kiện được mượn	Khách không bị khóa; có thẻ đang hiệu lực (chưa hủy, ngày hôm nay nằm trong khoảng hiệu lực); số sách đang mượn chưa đạt tối đa của gói; không còn sách quá hạn; không còn khoản nợ. Mỗi bản sao phải đang sẵn sàng, không thuộc loại “chỉ đọc tại chỗ” và đầu sách còn kinh doanh.
Hạn trả	Hôm nay cộng số ngày mượn của gói (ví dụ gói Thường: 14 ngày).
Phí thuê	Lấy theo từng đầu sách, lưu lại tại thời điểm cho mượn, thu khi trả sách.
Phạt trả trễ	Số ngày trễ nhân 2.000 đồng cho mỗi cuốn mỗi ngày, tối đa bằng giá đền của sách. Mức phạt cấu hình trong appsettings.json.
Sách hỏng	Thu phí thuê, phạt trễ (nếu có) và tiền đền (gợi ý 50% giá đền, có thể sửa).
Sách mất	Chỉ thu tiền đền (gợi ý bằng giá đền); bản sao chuyển sang trạng thái Mất.
Ghi nợ	Khoản chưa thu được ghi ở trạng thái “Còn nợ”; khách bị chặn mượn tiếp và chặn hoàn cọc cho đến khi thu nợ.
Gia hạn	Cộng thêm số ngày mượn của gói, tính từ hạn cũ. Chỉ khi: sách chưa trả và chưa quá hạn, khách không bị khóa, có thẻ hiệu lực, không có sách quá hạn khác, chưa hết số lần gia hạn của gói.

Quy tắc	Nội dung
Tiền cọc	Thu một lần khi mua thẻ đầu tiên; gia hạn thẻ không thu cọc lần hai. Hoàn khi khách trả thẻ (hủy thẻ), với điều kiện không còn sách chưa trả và không nợ; ghi vào sổ bằng số âm.
Gia hạn thẻ	Thẻ mới bắt đầu ngay sau ngày hết hạn của thẻ hiện có, để các thẻ nối tiếp nhau.
Không xóa cứng	Sách, bản sao, khách, giao dịch không bị xóa mà chuyển trạng thái (ngừng kinh doanh, thanh lý, đã hủy) để giữ lịch sử.

Quy trình phát triển phần mềm

Dự án được xây dựng theo **mô hình tăng dần (incremental)**: mỗi vòng lặp hoàn thành một nhóm chức năng có thể chạy và thử được, rồi mới sang vòng sau. Mỗi vòng gồm các bước phân tích, thiết kế, lập trình và chạy thử. Cách làm này giúp phát hiện lỗi sớm và cho phép điều chỉnh thiết kế (ví dụ rút gọn số bảng từ 21 xuống 10 bảng nghiệp vụ để kịp thời hạn).

Bảng 1.4. Các vòng lặp của dự án

Vòng	Nội dung	Kết quả
1	Phân tích, thiết kế CSDL, script tạo bảng, dữ liệu mẫu	17 bảng, tài khoản và dữ liệu mẫu
2	Khu quản trị: kho sách (tác giả, thể loại, sách, bản sao)	CRUD, tìm kiếm, phân trang, upload ảnh bìa
3	Gói thẻ và khách hàng, bán thẻ, cọc	Sổ giao dịch bắt đầu có dữ liệu
4	Mượn, trả, gia hạn, tính phạt, thu nợ	Nghiệp vụ trọng tâm
5	Sổ giao dịch, hủy giao dịch, báo cáo	5 báo cáo, xuất CSV
6	Cổng công khai và khu khách hàng, session, cookie	Theme tùy biến, đăng ký, tài khoản
7	REST API và AJAX	Tìm sách tức thì, gia hạn không tải lại trang
8	Quốc tế hóa và bảo mật bổ sung	Tiếng Việt, tiếng Anh; khóa tài khoản; header bảo mật
9	Kiểm thử, sửa lỗi, viết tài liệu	115 test case, báo cáo, hướng dẫn cài đặt

Công nghệ và công cụ sử dụng

Bảng 1.5. Công nghệ và công cụ

Thành phần	Công nghệ
Nền tảng, ngôn ngữ	ASP.NET Core MVC trên .NET 10, ngôn ngữ C#, giao diện Razor
Truy cập dữ liệu	Entity Framework Core 10 (nhà cung cấp SQL Server)
Cơ sở dữ liệu	SQL Server; bảng tạo bằng script SQL, quản lý bằng SQL Server Management Studio
Xác thực, phân quyền	ASP.NET Core Identity và Identity UI (đã tùy biến trang đăng nhập và đăng ký)

Thành phần	Công nghệ
Front-end	Bootstrap 5, jQuery (AJAX), CSS tùy biến
API	ASP.NET Core Web API (`[ApiController]`), JSON
Quốc tế hóa	`IStringLocalizer`, file tài nguyên `.resx`, `RequestLocalizationMiddleware`
Công cụ	Visual Studio, SQL Server Management Studio, trình duyệt (công cụ F12), draw.io, Graphviz

1.2. Khảo sát, phân tích yêu cầu để xác định các chức năng cho các lớp người dùng

Khảo sát

Việc khảo sát tập trung vào cách một quầy thư viện thực tế vận hành và các điểm khó của quy trình thủ công. Các vấn đề được ghi nhận và đã dẫn tới yêu cầu của hệ thống:

Bảng 1.6. Vấn đề của quy trình thủ công và yêu cầu rút ra

Vấn đề thực tế	Yêu cầu đặt ra cho hệ thống
Khó biết bản sách nào đang ở đâu, có bị mượn trùng không.	Quản lý theo bản sao có mã vạch; mỗi bản chỉ có một dòng mượn chưa trả, được ràng buộc ở cơ sở dữ liệu.
Quên hạn trả, tính phạt thủ công dễ sai.	Hạn trả lưu theo từng cuốn; hệ thống tự tính quá hạn, phạt và hiển thị sách quá hạn.
Thu nhiều loại tiền (phí thẻ, cọc, thuê, phạt, đền) dễ lẫn lộn, khó đối soát.	Một sổ giao dịch duy nhất, mỗi dòng có loại, số tiền, hình thức, trạng thái; tách doanh thu khỏi tiền cọc.
Khách không biết sách còn hay hết trước khi đến.	Tra cứu công khai hiển thị số bản còn mượn được và bản chỉ đọc tại chỗ.
Khách phải đến quầy chỉ để hỏi hạn trả hoặc xin gia hạn.	Khu tài khoản khách hàng xem sách đang mượn, hạn trả, nợ và gia hạn trực tuyến.
Nhân viên thao tác sai hoặc gian lận khó phát hiện.	Phân quyền hai vai trò; không xóa dữ liệu mà chỉ hủy kèm lý do; kiểm tra điều kiện ở máy chủ.

Việc khảo sát được thực hiện bằng cách phân tích quy trình hoạt động của một quầy thư viện (nhập sách, bán thẻ, mượn, trả, thu tiền, báo cáo) và đối chiếu với các yêu cầu của đề bài. Các vấn đề trên là cơ sở để xác định chức năng cho từng lớp người dùng ở phần tiếp theo.

Các lớp người dùng

Bảng 1.7. Các lớp người dùng

Lớp người dùng	Mô tả	Cách truy cập
Khách vãng lai	Người chưa đăng nhập, chỉ cần xem thông tin thư viện.	Phần công khai của website.
Khách hàng (role User)	Người đã đăng ký tài khoản, có hồ sơ thành viên; tự theo dõi thẻ, sách đang mượn và gia hạn.	Đăng nhập, khu `/My`.

Lớp người dùng	Mô tả	Cách truy cập
Quản trị viên (role Admin)	Người vận hành thư viện (chủ và nhân viên quầy được gộp thành một vai trò để đơn giản hóa phân quyền).	Đăng nhập, khu `/Admin`.

Chức năng cho từng lớp người dùng

Bảng 1.8. Chức năng của khách vãng lai

STT	Chức năng
1	Tra cứu sách theo tên, tác giả, ISBN; lọc theo thể loại; chỉ sách còn mượn được; sắp xếp; phân trang; tìm kiếm tức thì bằng AJAX.
2	Xem chi tiết sách, tình trạng còn sách, phí thuê, sách cùng thể loại; hệ thống nhớ sách xem gần đây (cookie).
3	Xem bảng giá các gói thẻ và quy định mượn, phạt.
4	Quản lý giỏ sách quan tâm (lưu trong session).
5	Đăng ký tài khoản, liên kết với hồ sơ đã tạo tại quầy; đăng nhập; đổi ngôn ngữ vi/en.

Bảng 1.9. Chức năng của khách hàng (User)

STT	Chức năng
1	Xem tổng quan: thẻ đang dùng, hạn thẻ, số sách đang mượn, khoản nợ, tiền cọc đang giữ, lý do chưa mượn được (nếu có).
2	Xem sách đang mượn, hạn trả (còn bao nhiêu ngày, quá hạn bao nhiêu ngày).
3	Gia hạn từng cuốn trực tuyến (AJAX), theo quy tắc của gói.
4	Xem lịch sử mượn trả và lịch sử thanh toán.
5	Cập nhật hồ sơ cá nhân; đổi mật khẩu.

Bảng 1.10. Chức năng của quản trị viên (Admin)

STT	Nhóm	Chức năng
1	Kho sách	CRUD tác giả, thể loại, đầu sách (ảnh bìa, phí thuê, giá đền); thêm bản sao với mã vạch tự sinh; đổi trạng thái bản sao.
2	Thẻ và khách hàng	CRUD gói thẻ; tạo hồ sơ khách, tìm và lọc theo tình trạng thẻ; bán, gia hạn thẻ, thu cọc; hoàn cọc, hủy thẻ; khóa, mở khóa khách.
3	Mượn, trả	Cho mượn bằng mã vạch với kiểm tra tự động; trả sách (bình thường, hỏng, mất) có tính tiền; gia hạn tại quầy; thu nợ; in phiếu mượn.
4	Thu tiền	Sổ giao dịch (lọc, phân trang, xuất CSV); hủy giao dịch có lý do.
5	Báo cáo	Doanh thu; sách quá hạn; sách mượn nhiều và tồn lâu; thẻ sắp hết hạn; kho sách.

Phân quyền

Bảng 1.11. Ma trận phân quyền

Chức năng	Khách vãng lai	User	Admin
Tra cứu sách, xem bảng giá, giỏ quan tâm	Có	Có	Có
Đăng ký, đăng nhập, đổi ngôn ngữ	Có	Có	Có
Xem thẻ, sách đang mượn, lịch sử, nợ của chính mình	Không	Có	Không
Gia hạn trực tuyến	Không	Có (sách của mình)	Không
Quản lý sách, bản sao, tác giả, thể loại	Không	Không	Có
Quản lý gói, khách hàng, bán thẻ, hoàn cọc	Không	Không	Có
Cho mượn, trả, gia hạn tại quầy, thu nợ	Không	Không	Có
Sổ giao dịch, hủy giao dịch, báo cáo	Không	Không	Có

Yêu cầu phi chức năng

- **Bảo mật:** mật khẩu được băm; phân quyền theo vai trò; chống CSRF, XSS, SQL injection; khóa tài khoản khi đăng nhập sai nhiều lần; khách chỉ truy cập dữ liệu của mình.
- **Toàn vẹn dữ liệu:** khóa ngoại, ràng buộc duy nhất, chỉ mục lọc chống mượn trùng, kiểm soát đồng thời; không xóa cứng; tiền dùng `decimal(18,0)`.
- **Khả dụng:** giao diện đáp ứng (Responsive) trên máy tính và điện thoại; thông báo lỗi rõ ràng; tìm kiếm tức thì.
- **Quốc tế hóa:** khu công khai và khu khách hàng hỗ trợ tiếng Việt và tiếng Anh, định dạng ngày và số theo ngôn ngữ.
- **Bảo trì:** quy tắc nghiệp vụ tập trung ở tầng dịch vụ (`LoanRules`), dùng chung cho khu quản trị, khu khách hàng và API; tham số (mức phạt) nằm trong cấu hình.

Đối chiếu yêu cầu của đề bài

Bảng 1.12. Đối chiếu yêu cầu của đề bài với hệ thống

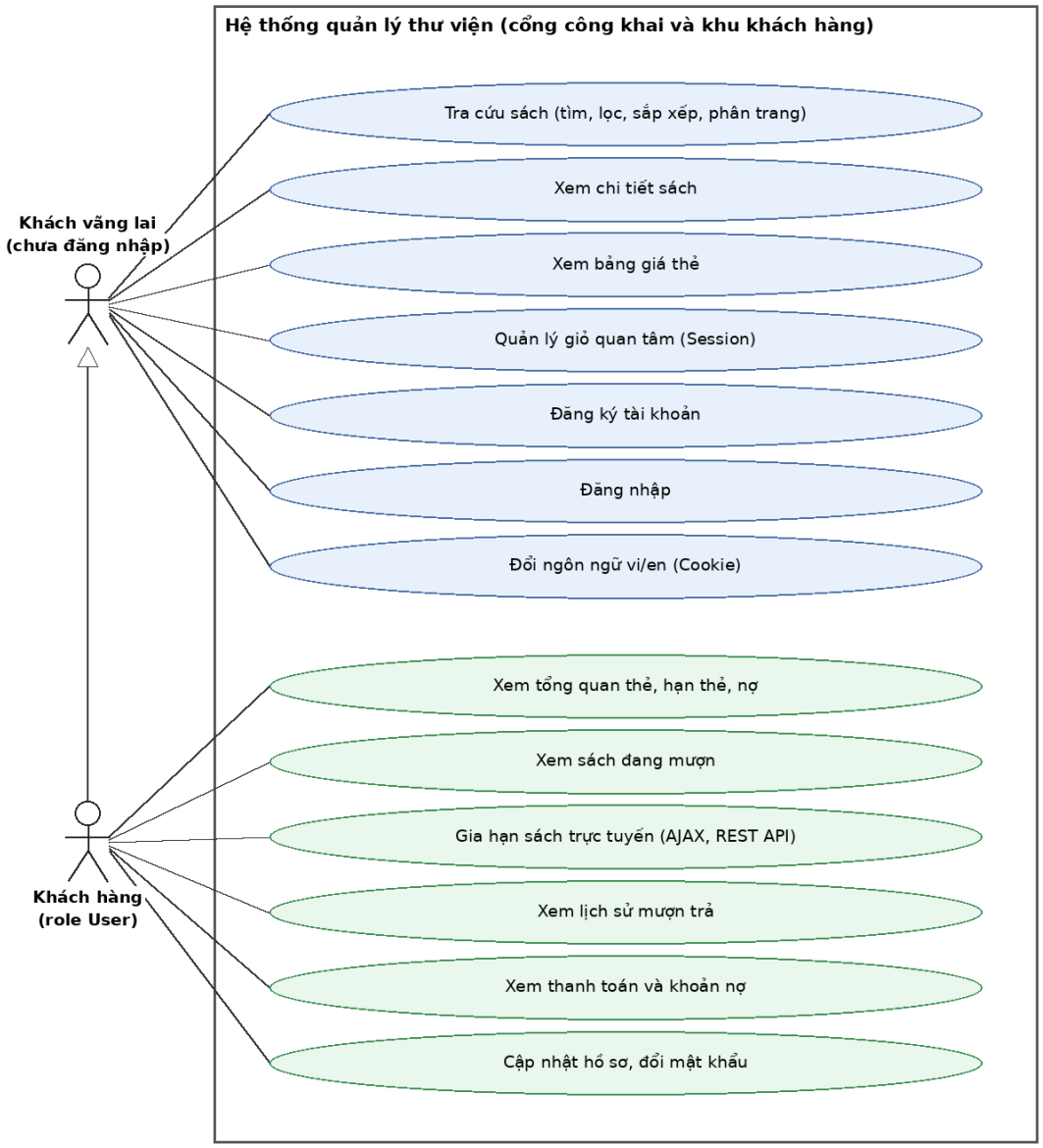
Yêu cầu của đề bài	Cách thực hiện trong hệ thống
Nhiều lớp người dùng, nhiều cấu phần	Hai vai trò Admin và User cùng phần công khai; khu `/Admin` (Area riêng) và khu `/My`.
Thiết kế hoặc tùy biến template	Theme riêng `portal.css` trên Bootstrap 5 cho giao diện công khai và khách hàng; bố cục quản trị có thanh bên riêng.
Responsive	Bootstrap grid, menu thu gọn trên màn hình nhỏ, bảng cuộn ngang, lưới sách tự co.
Paging	Phân trang phía máy chủ ở danh sách sách, khách, phiếu mượn, giao dịch; “Xem thêm” bằng AJAX ở trang tra cứu.
Filtering	Lọc theo từ khóa, thể loại, tình trạng thẻ, khoảng ngày, loại và trạng thái giao dịch.

Yêu cầu của đề bài	Cách thực hiện trong hệ thống
AJAX	Tìm kiếm sách tức thì và gia hạn không tải lại trang (jQuery gọi REST API).
CRUD	Tác giả, thể loại, đầu sách, bản sao, gói thẻ, khách hàng và các thao tác nghiệp vụ trên phiếu mượn, giao dịch.
Session, cookie	Session: giỏ sách quan tâm. Cookie: sách xem gần đây, ngôn ngữ, cookie đăng nhập.
Annotation	Data Annotations trên model và ViewModel (`Required`, `StringLength`, `Range`, `RegularExpression`, `Display`...).
Web API RESTful	`/api/books`, `/api/books/{id}`, `/api/categories`, `/api/me/loans`, `/api/me/loans/{id}/renew`.
Security	Identity, phân quyền, anti-forgery, mã hóa đầu ra, truy vấn tham số hóa, khóa tài khoản, header bảo mật, kiểm tra quyền sở hữu dữ liệu.
Quốc tế hóa	Tiếng Việt và tiếng Anh bằng file tài nguyên `.resx`, ngôn ngữ lưu trong cookie.

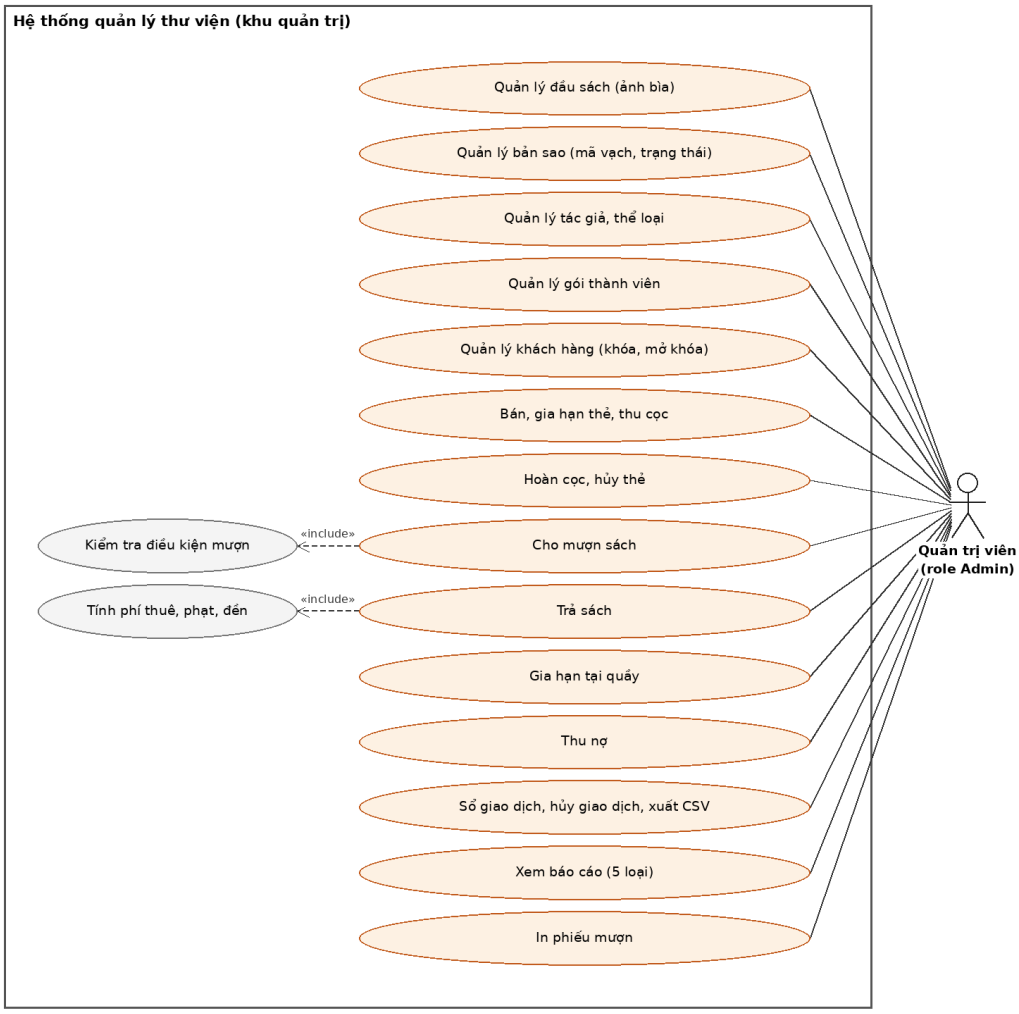
CHƯƠNG 2. THIẾT KẾ

2.1. Vẽ use-case diagram

Sơ đồ use-case được chia theo nhóm tác nhân để dễ đọc: Khách vãng lai và Khách hàng (Khách hàng kế thừa mọi chức năng của Khách vãng lai), và Quản trị viên.



Hình 2.1. Use-case của khách vãng lai và khách hàng



Hình 2.2. Use-case của quản trị viên

Đặc tả một số use-case chính

Bảng 2.1. Đặc tả use-case "Cho mượn sách"

Mục	Nội dung
Tác nhân	Quản trị viên
Tiền điều kiện	Đã đăng nhập role Admin; khách đã có hồ sơ.
Luồng chính	1. Admin nhập mã thành viên, số điện thoại hoặc tên để tìm khách. 2. Hệ thống hiển thị thẻ, số sách đang mượn và kiểm tra điều kiện mượn. 3. Admin nhập mã vạch các cuốn (mỗi mã một dòng). 4. Hệ thống kiểm tra từng mã: tồn tại, sẵn sàng, không chỉ đọc tại chỗ, sách còn kinh doanh, không vượt số sách tối đa. 5. Hệ thống tạo phiếu mượn, đặt hạn trả theo gói, chuyển các bản sao sang "Đang mượn". 6. Hiển thị phiếu mượn, cho phép in.
Luồng thay thế	2a. Khách bị khóa, hết hạn thẻ, đủ số sách, còn quá hạn hoặc còn nợ: hiển thị lý do, không cho mượn. 4a. Có mã không hợp lệ: hiển thị lỗi từng mã, không tạo phiếu. 5a. Hai Admin cùng mượn một bản: người đến sau nhận thông báo, dữ liệu không bị trùng.

Mục	Nội dung
Hậu điều kiện	Phiếu mượn được ghi; trạng thái các bản sao cập nhật; không có bản sao nào có hai dòng mượn chưa trả.

Bảng 2.2. Đặc tả use-case "Trả sách"

Mục	Nội dung
Tác nhân	Quản trị viên
Tiền điều kiện	Có dòng mượn chưa trả của bản sao cần trả.
Luồng chính	1. Admin quét hoặc nhập mã vạch (hoặc bấm Trả trong danh sách sách đang mượn). 2. Hệ thống hiển thị thông tin cuốn sách, hạn trả, số ngày trễ, phí thuê, phạt trễ. 3. Admin chọn: trả bình thường, hỏng hoặc mất; chọn thu ngay hay ghi nợ. 4. Hệ thống tính lại tiền từ dữ liệu trong CSDL, ghi các khoản vào sổ giao dịch, cập nhật dòng mượn và bản sao.
Luồng thay thế	3a. Sách mất mà không nhập tiền đền: báo lỗi. 3b. Ghi nợ: khoản ở trạng thái "Còn nợ", khách bị chặn mượn đến khi thu nợ.
Hậu điều kiện	Bản sao ở trạng thái Sẵn sàng, Hỏng hoặc Mất; số tiền thu khớp với tổng hiển thị.

Bảng 2.3. Đặc tả use-case "Gia hạn sách trực tuyến"

Mục	Nội dung
Tác nhân	Khách hàng (User)
Tiền điều kiện	Đã đăng nhập; sách đang mượn thuộc về khách.
Luồng chính	1. Khách mở "Sách đang mượn" và bấm Gia hạn. 2. Trình duyệt gửi yêu cầu POST tới API kèm token chống CSRF. 3. Máy chủ kiểm tra sách thuộc khách và kiểm tra quy tắc gia hạn. 4. Hạn trả cộng thêm số ngày mượn của gói, số lần gia hạn tăng. 5. Giao diện cập nhật tại chỗ và hiển thị thông báo.
Luồng thay thế	3a. Sách quá hạn, hết lượt gia hạn, có sách quá hạn khác, thẻ hết hạn hoặc khách bị khóa: API trả mã 409 kèm lý do, hiển thị thông báo đỏ. 3b. Sách của người khác: trả 404.
Hậu điều kiện	Dữ liệu chỉ thay đổi khi mọi điều kiện thỏa mãn.

Bảng 2.4. Đặc tả use-case "Bán, gia hạn thẻ"

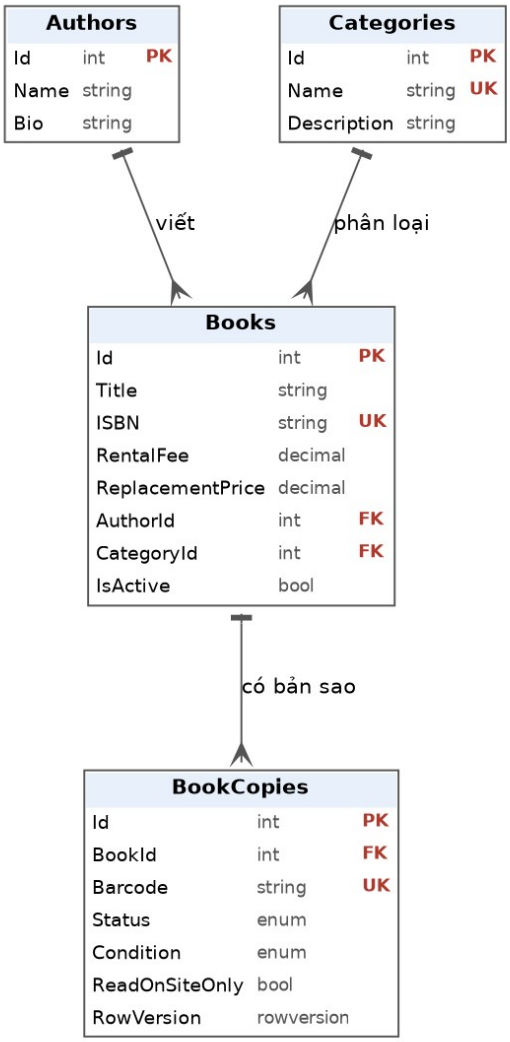
Mục	Nội dung
Tác nhân	Quản trị viên
Tiền điều kiện	Khách có hồ sơ và không bị khóa.

Mục	Nội dung
Luồng chính	1. Admin mở hồ sơ khách và chọn Bán / gia hạn thẻ. 2. Hệ thống liệt kê các gói đang bán kèm phí, cọc, tổng thu (không thu cọc nếu khách đang giữ cọc). 3. Admin chọn gói và hình thức thanh toán, xác nhận. 4. Hệ thống tạo thẻ (bắt đầu hôm nay, hoặc ngay sau thẻ hiện có) và các biên lai phí thẻ, tiền cọc trong cùng một lần lưu.
Hậu điều kiện	Thẻ và biên lai cùng được ghi hoặc cùng không được ghi.

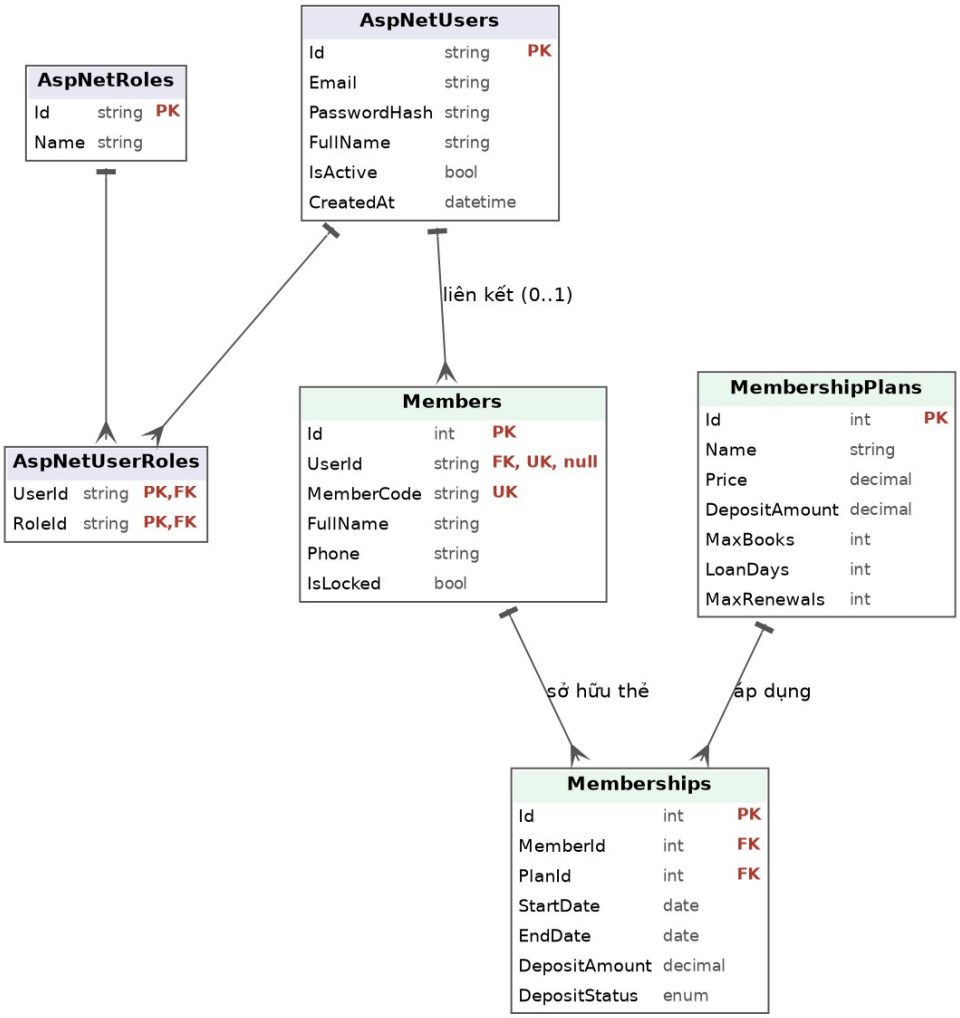
2.2. Thiết kế cơ sở dữ liệu: ERD, mô tả về dữ liệu, các ràng buộc

Sơ đồ quan hệ thực thể (ERD)

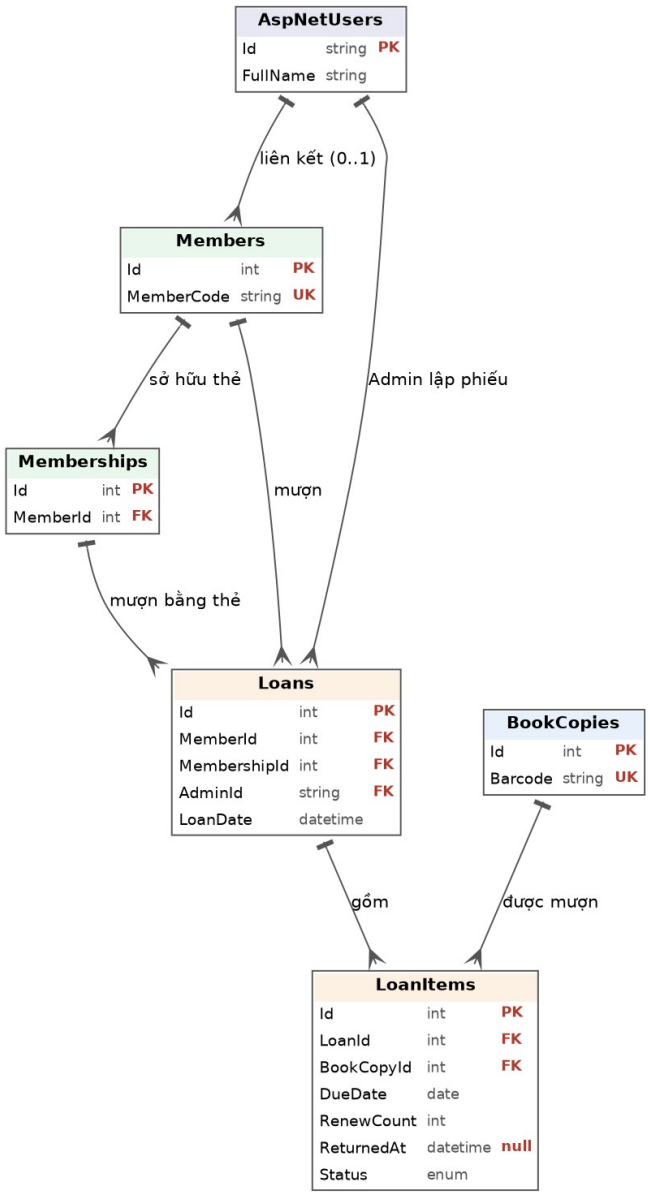
Cơ sở dữ liệu có **17 bảng**: 7 bảng của ASP.NET Core Identity (tài khoản, vai trò...) và **10 bảng nghiệp vụ**. Để dễ đọc, ERD được chia thành bốn phần theo nhóm chức năng.



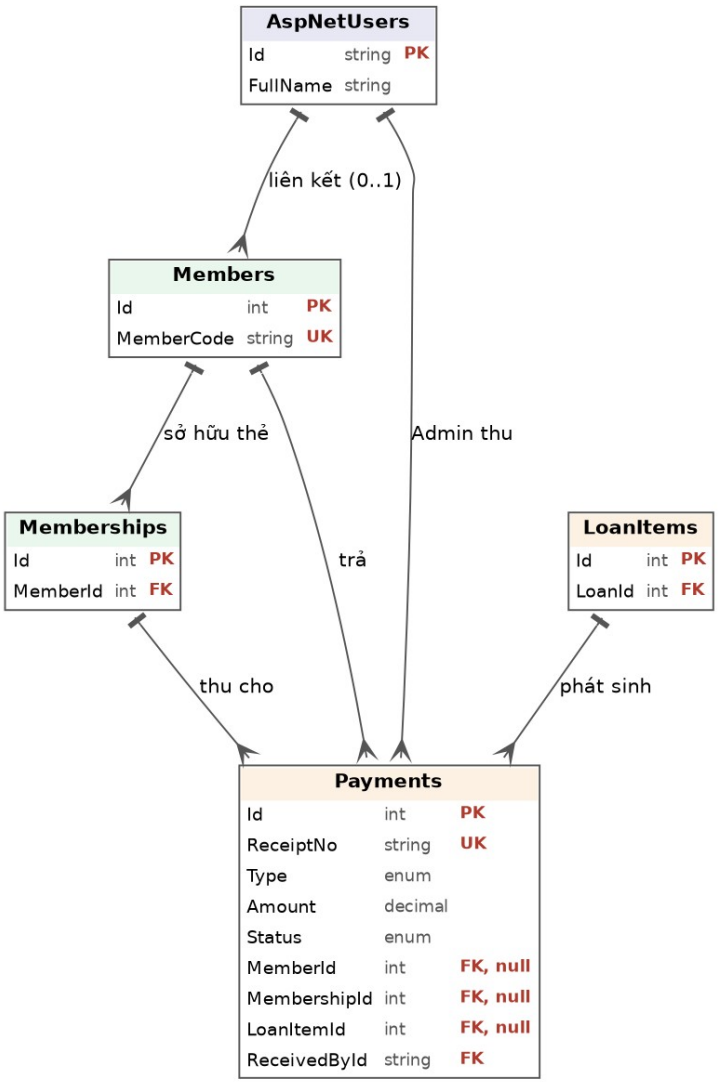
Hình 2.3. ERD phần kho sách (Authors, Categories, Books, BookCopies)



Hình 2.4. ERD phần tài khoản, thành viên và thẻ



Hình 2.5. ERD phần mượn trả (các bảng ngoài phần này chỉ hiện cột chính)



Hình 2.6. ERD phần thanh toán

Quan hệ chính: một tác giả và một thể loại có nhiều sách; một sách có nhiều bản sao; một khách có nhiều thẻ và nhiều phiếu mượn; một phiếu mượn gồm nhiều dòng (mỗi dòng ứng với một bản sao); một khoản thanh toán có thể gắn với khách, thẻ hoặc dòng mượn (các khóa này cho phép rỗng). Hồ sơ khách (`Members`) tách khỏi tài khoản đăng nhập (`AspNetUsers`) và liên kết tùy chọn 0..1, vì khách có thể được tạo hồ sơ tại quầy trước khi đăng ký tài khoản web.

Mô tả dữ liệu

Các bảng nghiệp vụ được mô tả dưới đây. Giá trị kiểu liệt kê (enum) được lưu dạng số nguyên.

Bảng 2.5. Bảng Authors (tác giả)

Cột	Kiểu dữ liệu	Ràng buộc	Mô tả
Id	int	PK, identity	Mã tác giả
Name	nvarchar(150)	NOT NULL	Tên tác giả
Bio	nvarchar(max)	NULL	Tiểu sử

Bảng 2.6. Bảng Categories (thể loại)

Cột	Kiểu dữ liệu	Ràng buộc	Mô tả
Id	int	PK, identity	Mã thể loại
Name	nvarchar(100)	NOT NULL, duy nhất	Tên thể loại
Description	nvarchar(500)	NULL	Mô tả

Bảng 2.7. Bảng Books (đầu sách)

Cột	Kiểu dữ liệu	Ràng buộc	Mô tả
Id	int	PK, identity	Mã đầu sách
Title	nvarchar(250)	NOT NULL, có chỉ mục	Tên sách
ISBN	nvarchar(20)	NOT NULL, duy nhất	Mã ISBN
Description	nvarchar(max)	NULL	Mô tả
Publisher	nvarchar(150)	NULL	Nhà xuất bản
PublishYear, PageCount	int	NULL	Năm xuất bản, số trang
CoverImagePath	nvarchar(300)	NULL	Đường dẫn ảnh bìa (wwwroot/covers)
RentalFee	decimal(18,0)	NOT NULL	Phí thuê một lần (0 nếu miễn phí)
ReplacementPrice	decimal(18,0)	NOT NULL	Giá đền khi mất hoặc hỏng
AuthorId	int	FK → Authors	Tác giả
CategoryId	int	FK → Categories	Thể loại
IsActive	bit	NOT NULL	Còn kinh doanh hay ngừng

Bảng 2.8. Bảng BookCopies (bản sao vật lý)

Cột	Kiểu dữ liệu	Ràng buộc	Mô tả
Id	int	PK, identity	Mã bản sao
BookId	int	FK → Books	Đầu sách
Barcode	nvarchar(30)	NOT NULL, duy nhất	Mã vạch, dạng BC + mã sách 4 số + số thứ tự 2 số
Status	int	NOT NULL	0 Sẵn sàng, 1 Đang mượn, 2 Mất, 3 Hỏng, 4 Đã thanh lý
Condition	int	NOT NULL	0 Mới, 1 Tốt, 2 Cũ
ShelfLocation	nvarchar(50)	NULL	Vị trí kệ
ReadOnSiteOnly	bit	NOT NULL	Chỉ đọc tại chỗ, không cho mượn về

Cột	Kiểu dữ liệu	Ràng buộc	Mô tả
PurchasePrice, AcquiredDate	decimal, datetime2	NOT NULL	Giá nhập, ngày nhập
RowVersion	rowversion	NOT NULL	Phiên bản dòng để kiểm soát đồng thời

Bảng 2.9. Bảng MembershipPlans (gói thẻ)

Cột	Kiểu dữ liệu	Ràng buộc	Mô tả
Id	int	PK, identity	Mã gói
Name	nvarchar(100)	NOT NULL	Tên gói
Price	decimal(18,0)	NOT NULL	Phí gói
DurationMonths	int	NOT NULL	Thời hạn (tháng)
DepositAmount	decimal(18,0)	NOT NULL	Tiền cọc
MaxBooks	int	NOT NULL	Số sách mượn tối đa cùng lúc
LoanDays	int	NOT NULL	Số ngày được mượn mỗi cuốn
MaxRenewals	int	NOT NULL	Số lần gia hạn tối đa
IsActive	bit	NOT NULL	Đang bán hay ngừng bán

Bảng 2.10. Bảng Members (hồ sơ khách)

Cột	Kiểu dữ liệu	Ràng buộc	Mô tả
Id	int	PK, identity	Mã hồ sơ
UserId	nvarchar(450)	FK → AspNetUsers, NULL, duy nhất khi có giá trị	Tài khoản web liên kết
MemberCode	nvarchar(20)	NOT NULL, duy nhất	Mã thành viên, dạng TV000001
FullName	nvarchar(100)	NOT NULL	Họ tên
Phone	nvarchar(15)	NOT NULL, có chỉ mục	Số điện thoại
Email, Address	nvarchar	NULL	Email, địa chỉ
DateOfBirth	datetime2	NULL	Ngày sinh
IsLocked, LockReason	bit, nvarchar(250)	NOT NULL, NULL	Trạng thái khóa và lý do
CreatedAt	datetime2	NOT NULL	Ngày tạo hồ sơ

Bảng 2.11. Bảng Memberships (thẻ thành viên)

Cột	Kiểu dữ liệu	Ràng buộc	Mô tả
Id	int	PK, identity	Mã thẻ
MemberId, PlanId	int	FK → Members, MembershipPlans	Khách và gói
StartDate, EndDate	datetime2	NOT NULL	Khoảng hiệu lực
PricePaid	decimal(18,0)	NOT NULL	Phí đã trả (lưu giá lúc mua)
DepositAmount	decimal(18,0)	NOT NULL	Tiền cọc của thẻ này
DepositStatus	int	NOT NULL	0 Đang giữ, 1 Đã hoàn, 2 Mất cọc
Status	int	NOT NULL	0 Hiệu lực, 1 Hết hạn, 2 Đã hủy

Bảng 2.12. Bảng Loans (phiếu mượn)

Cột	Kiểu dữ liệu	Ràng buộc	Mô tả
Id	int	PK, identity	Mã phiếu (hiển thị PM + 5 số)
MemberId	int	FK → Members	Khách mượn
MembershipId	int	FK → Memberships	Thẻ dùng để mượn
AdminId	nvarchar(450)	FK → AspNetUsers	Admin lập phiếu
LoanDate	datetime2	NOT NULL	Thời điểm lập phiếu
Note	nvarchar(250)	NULL	Ghi chú

Bảng 2.13. Bảng LoanItems (từng cuốn trong phiếu)

Cột	Kiểu dữ liệu	Ràng buộc	Mô tả
Id	int	PK, identity	Mã dòng mượn
LoanId	int	FK → Loans	Phiếu mượn
BookCopyId	int	FK → BookCopies	Bản sao được mượn
DueDate	datetime2	NOT NULL	Hạn trả (cập nhật khi gia hạn)
RenewCount	int	NOT NULL	Số lần đã gia hạn
RentalFeeCharged	decimal(18,0)	NOT NULL	Phí thuê lưu lúc mượn
ReturnedAt	datetime2	NULL	Ngày đóng dòng mượn; NULL nghĩa là chưa trả
ConditionOnReturn	int	NULL	Tình trạng sách khi trả
Status	int	NOT NULL	0 Đang mượn, 1 Đã trả, 2 Mất

Bảng 2.14. Bảng Payments (sổ giao dịch)

Cột	Kiểu dữ liệu	Ràng buộc	Mô tả
Id	int	PK, identity	Mã giao dịch
ReceiptNo	nvarchar(20)	NOT NULL, duy nhất	Số biên lai, dạng PT000001
Type	int	NOT NULL	0 Phí thẻ, 1 Cọc, 2 Hoàn cọc, 3 Phí thuê, 4 Phạt trễ, 5 Đền sách
Amount	decimal(18,0)	NOT NULL	Số tiền (hoàn cọc ghi số âm)
Method	int	NOT NULL	0 Tiền mặt, 1 Chuyển khoản
Status	int	NOT NULL	0 Đã thu, 1 Còn nợ, 2 Đã hủy
MemberId, MembershipId, LoanItemId	int	FK, NULL	Khoản này thu cho khách, thẻ hoặc dòng mượn nào
ReceivedById	nvarchar(450)	FK → AspNetUsers	Admin thu tiền
CreatedAt, PaidAt	datetime2	NOT NULL, NULL	Thời điểm ghi, thời điểm thu (NULL nếu còn nợ)
Note, VoidReason	nvarchar(250)	NULL	Ghi chú, lý do hủy

Bảng của Identity: `AspNetUsers` (mở rộng thêm `FullName`, `IsActive`, `CreatedAt`), `AspNetRoles` (hai dòng: Admin, User), `AspNetUserRoles`, `AspNetUserClaims`, `AspNetUserLogins`, `AspNetUserTokens`, `AspNetRoleClaims`.

Các ràng buộc

Bảng 2.15. Các ràng buộc dữ liệu

Loại	Ràng buộc	Mục đích
Khóa duy nhất	`Books.ISBN`, `BookCopies.Barcode`, `Members.MemberCode`, `Payments.ReceiptNo`, `Categories.Name`	Không trùng mã định danh.
Khóa duy nhất có điều kiện	`Members.UserId` (chỉ khi khác NULL)	Mỗi tài khoản chỉ gắn một hồ sơ, vẫn cho phép nhiều hồ sơ chưa liên kết.
Chỉ mục lọc	`UX_LoanItems_ActiveCopy`: duy nhất trên `LoanItems(BookCopyId)` khi `ReturnedAt IS NULL`	Một bản sao chỉ có tối đa một dòng mượn chưa trả: cơ sở dữ liệu tự chặn mượn trùng dù hai Admin thao tác cùng lúc.
Kiểm soát đồng thời	Cột `RowVersion` của `BookCopies`	Phát hiện hai người cùng sửa một bản sao.
Khóa ngoại	Mọi khóa ngoại nghiệp vụ dùng NO ACTION (không xóa dây chuyền)	Không xóa nhầm dữ liệu có liên quan; hệ thống chỉ chuyển trạng thái.

Loại	Ràng buộc	Mục đích
Dữ liệu dẫn xuất không lưu	Số bản còn lại, "quá hạn", số tiền phạt đang chạy	Luôn tính từ dữ liệu gốc nên không bao giờ lệch.
Snapshot	`Memberships.PricePaid`, `LoanItems.RentalFeeCharged`	Đổi giá gói hoặc phí thuê về sau không ảnh hưởng dữ liệu cũ.
Kiểu tiền	`decimal(18,0)`	Đồng Việt Nam không có số lẻ, tránh sai số.
Bất biến sổ giao dịch	Không xóa dòng `Payments`, chỉ chuyển sang Đã hủy kèm lý do; hoàn cọc là số âm	Truy vết được mọi thay đổi tiền.

Quy ước mã tự sinh

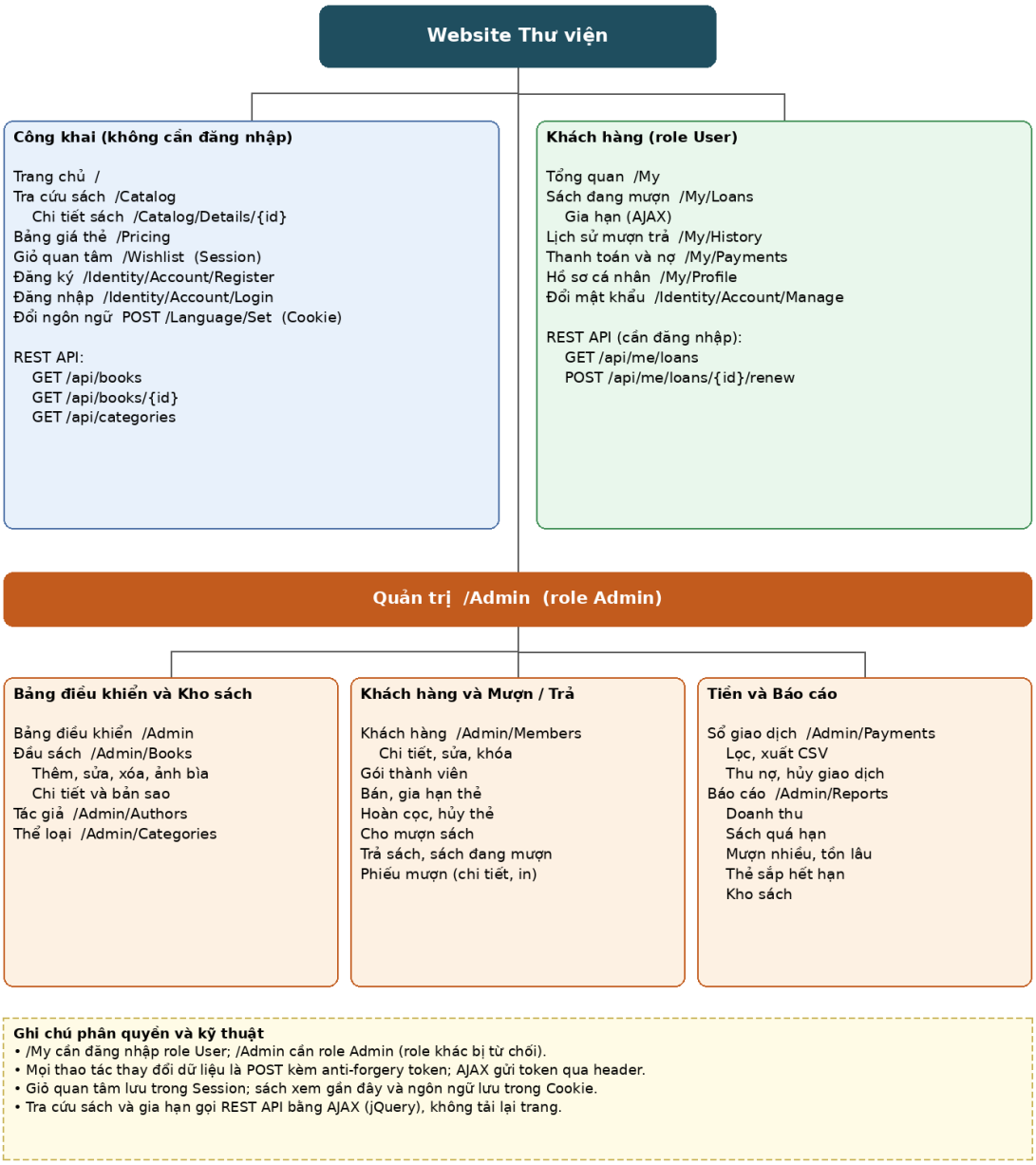
Bảng 2.16. Mã tự sinh

Đối tượng	Dạng mã	Ví dụ
Thành viên	TV + 6 số tăng dần	TV000001
Biên lai	PT + 6 số tăng dần	PT000003
Bản sao (mã vạch)	BC + mã sách 4 số + số thứ tự bản 2 số	BC000102
Phiếu mượn (hiển thị)	PM + mã phiếu 5 số	PM00001

2.3. Vẽ sitemap và wireframe bằng công cụ draw.io

Sitemap

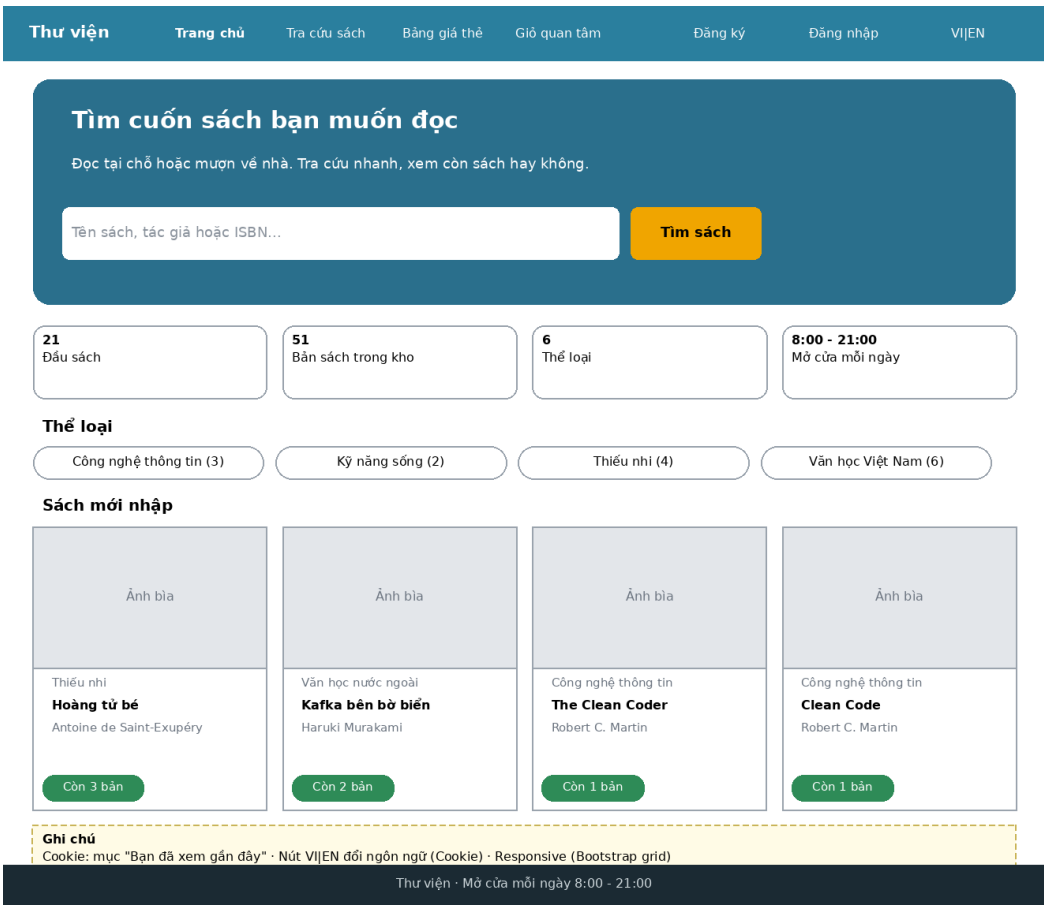
Sitemap thể hiện cấu trúc trang của website theo ba khu vực: công khai, khách hàng (cần đăng nhập role User) và quản trị (cần role Admin).



Hình 2.7. Sitemap của website

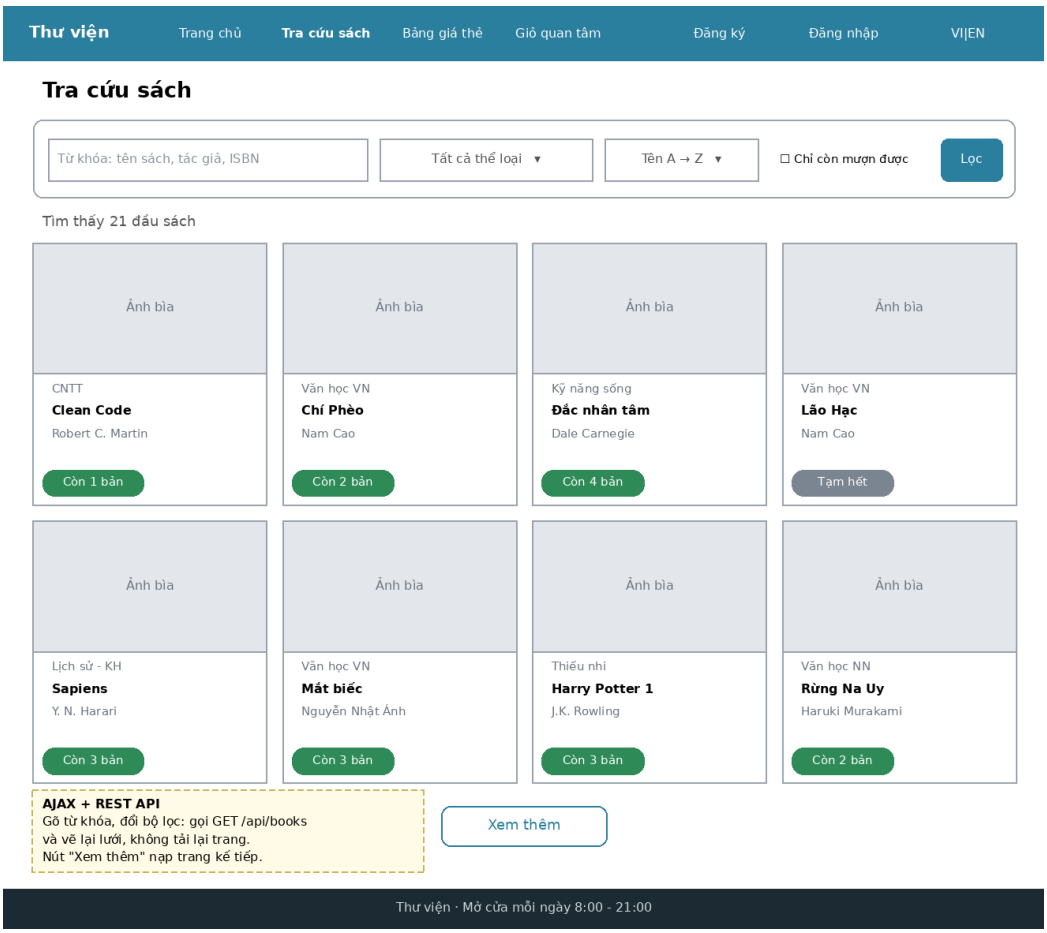
Wireframe

Sáu wireframe dưới đây phác thảo bố cục các màn hình tiêu biểu trước khi lập trình. Giao diện thực tế được trình bày ở mục 3.2.



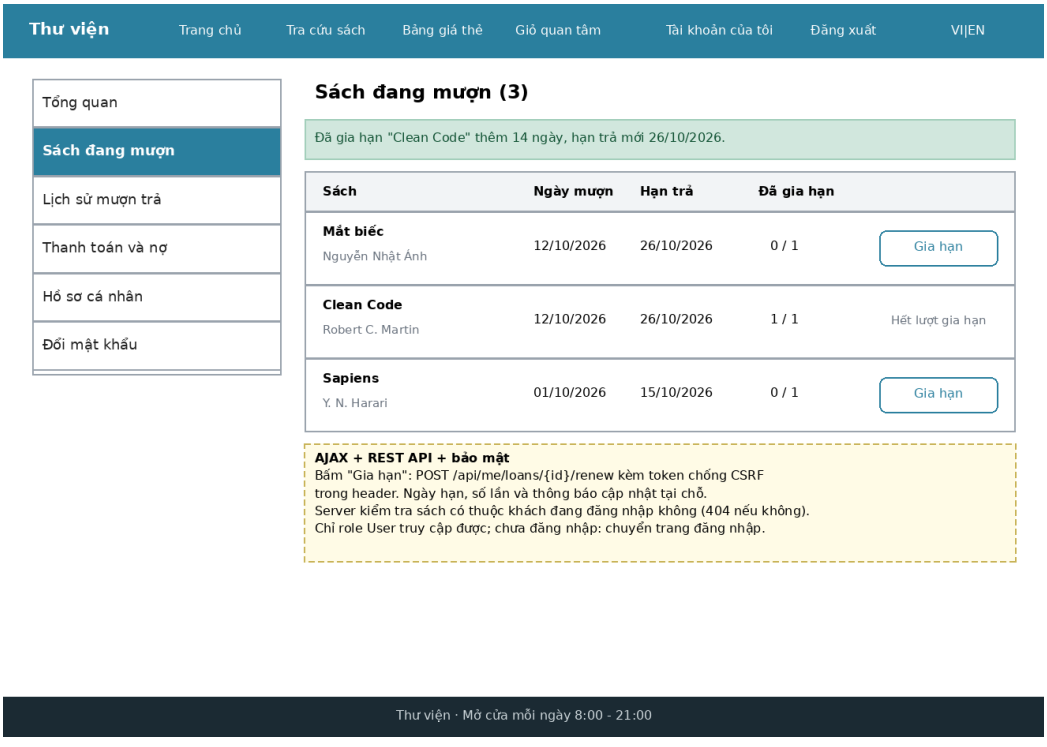
Hình 2.8. Wireframe trang chủ công khai

Trang chủ gồm thanh điều hướng, khung tìm kiếm lớn, các ô số liệu, danh sách thể loại, mục “Bạn đã xem gần đây” (cookie) và sách mới nhập.



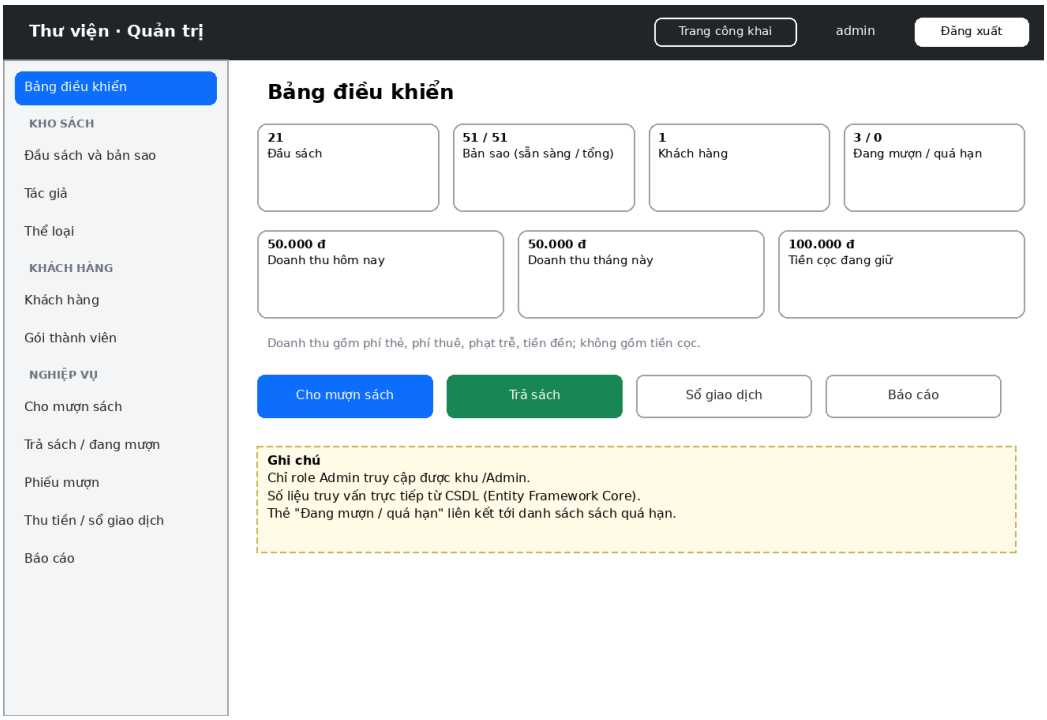
Hình 2.9. Wireframe trang tra cứu sách

Thanh lọc (từ khóa, thể loại, sắp xếp, chỉ sách còn mượn được) nằm phía trên lưới thẻ sách; nút “Xem thêm” và AJAX thay cho tải lại trang.



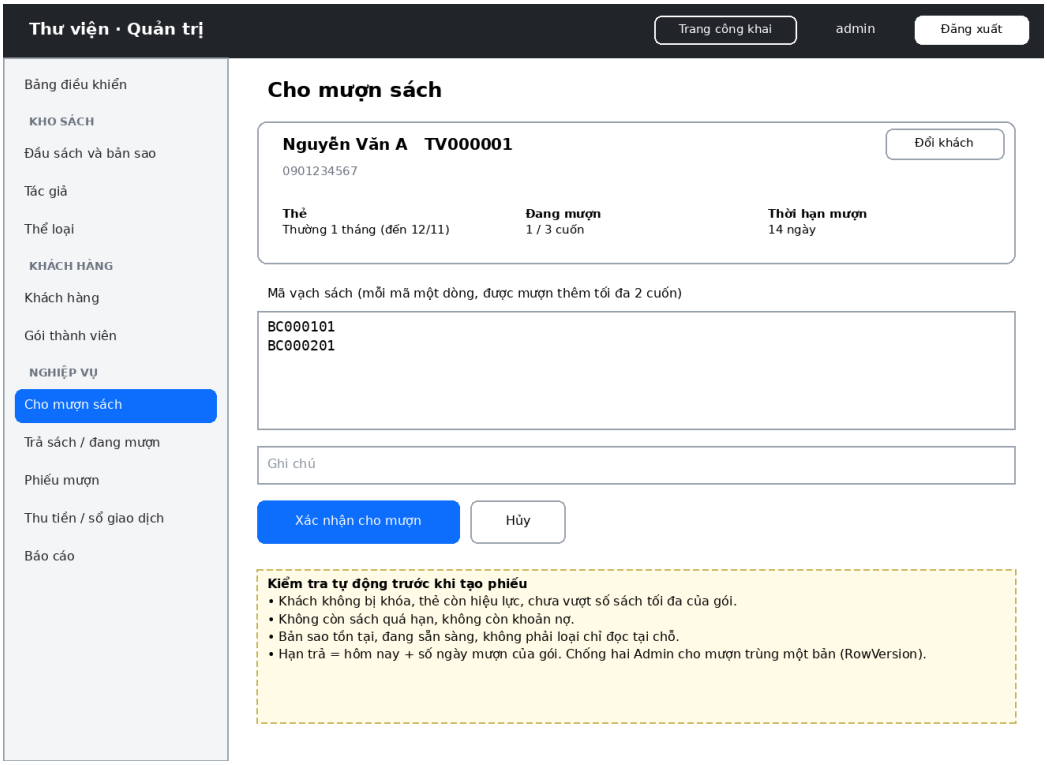
Hình 2.10. Wireframe trang “Sách đang mượn” của khách hàng

Menu tài khoản bên trái, bảng sách đang mượn bên phải với nút Gia hạn; thông báo kết quả hiện ngay trên trang.



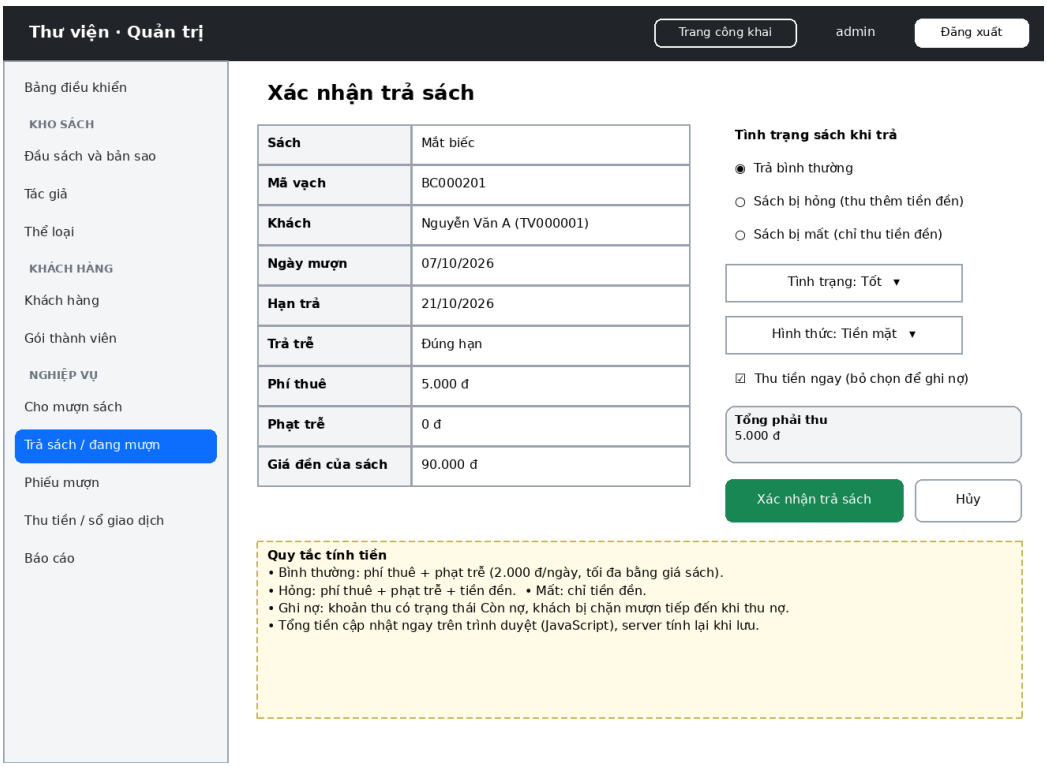
Hình 2.11. Wireframe bảng điều khiển quản trị

Bố cục quản trị gồm thanh trên, thanh bên chia nhóm chức năng, các thẻ số liệu và nút tới các thao tác chính.



Hình 2.12. Wireframe màn hình cho mượn sách

Admin tìm khách, xem điều kiện mượn, nhập mã vạch từng dòng rồi xác nhận; mọi điều kiện được kiểm tra tự động.



Hình 2.13. Wireframe màn hình xác nhận trả sách

Bên trái là thông tin dòng mượn và các khoản phí tính sẵn; bên phải chọn tình trạng sách, hình thức thanh toán, thu ngay hay ghi nợ và xem tổng phải thu.

Thiết kế giao diện (template tùy biến)

Giao diện công khai và khu khách hàng dùng một **theme riêng** xây trên Bootstrap 5, đặt trong `wwwroot/css/portal.css`. Layout dùng chung `_Layout.cshtml` cũng được trang đăng nhập và đăng ký sử dụng nên toàn website nhất quán. Khu quản trị có layout riêng `_AdminLayout.cshtml` với thanh bên chia nhóm chức năng.

Bảng 2.17. Các yếu tố của theme

Yếu tố	Thiết kế
Màu sắc	Xanh lam đậm làm màu chủ đạo (#1F4E5F, #2A7F9E), màu nhấn vàng cam cho nút tìm kiếm; nền xám nhạt; trạng thái dùng màu của Bootstrap (xanh = còn sách, xám = tạm hết, đỏ = quá hạn).
Thanh điều hướng	Nền gradient, thu gọn thành nút menu trên màn hình nhỏ, có huy hiệu số sách trong giỏ quan tâm và nút đổi ngôn ngữ.
Khối chính	Khối “hero” có ô tìm kiếm lớn; ô số liệu bo góc có bóng nhẹ.
Thẻ sách	Ảnh bìa tỷ lệ 3:4; nếu chưa có ảnh thì hiện chữ cái đầu trên nền màu tạo từ mã sách; nhãn tình trạng còn sách.
Responsive	Lưới 2 cột trên điện thoại, 3 cột trên máy tính bảng, 4 cột trên máy tính; bảng bọc trong vùng cuộn ngang.

CHƯƠNG 3. TRIỂN KHAI

3.1. Lập trình xây dựng các chức năng cho hệ thống

Môi trường phát triển

Bảng 3.1. Môi trường phát triển và chạy thử

Thành phần	Phiên bản, thông số
Hệ điều hành	Windows 11
SDK, framework	.NET 10 (ASP.NET Core MVC), C#
Cơ sở dữ liệu	SQL Server (bản cài đặt trên máy phát triển), SQL Server Management Studio
Gói NuGet chính	Microsoft.EntityFrameworkCore.SqlServer, Microsoft.EntityFrameworkCore.Tools, Microsoft.AspNetCore.Identity.EntityFrameworkCore, Microsoft.AspNetCore.Identity.UI (đều bản 10.x)
Trình duyệt kiểm thử	Google Chrome

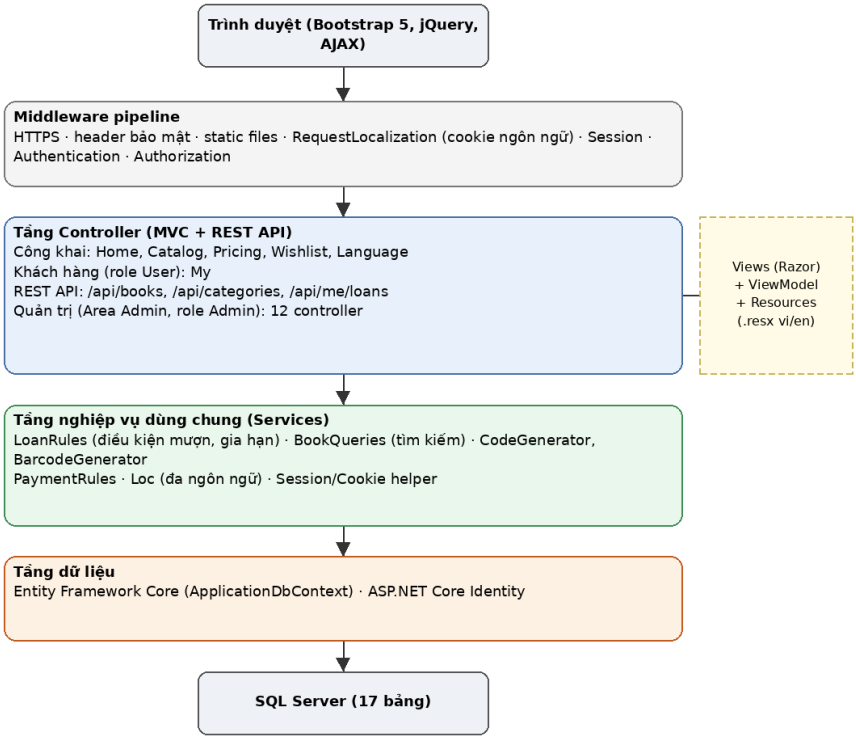
Cấu trúc thư mục của dự án được trình bày ở bảng dưới đây. Cách tổ chức tách khu quản trị (Area `Admin`), khu công khai và khách hàng (thư mục `Controllers` gốc), REST API (`Controllers/Api`) và các dịch vụ dùng chung (`Services`).

Bảng 3.2. Cấu trúc thư mục chính của dự án

Thư mục, tệp	Vai trò
`Program.cs`, `appsettings.json`	Cấu hình dịch vụ, middleware; chuỗi kết nối và mức phạt trả trễ
`Areas/Admin`	Khu quản trị (role Admin): 12 controller, các dịch vụ nghiệp vụ, ViewModel, view
`Areas/Identity/Pages/Account`	Trang đăng nhập và đăng ký đã tùy biến
`Controllers`, `Controllers/Api`	Controller công khai và khách hàng (Home, Catalog, Pricing, Wishlist, My, Language) và 3 controller REST API
`Data`	`ApplicationDbContext` (cấu hình quan hệ, chỉ mục), `DbSeeder` (vai trò, tài khoản, dữ liệu mẫu)
`Models`	10 entity nghiệp vụ, `ApplicationUser`, các kiểu liệt kê
`Services`	Tìm kiếm dùng chung, hỗ trợ session và cookie, đa ngôn ngữ
`Resources`	Tệp tài nguyên ngôn ngữ tiếng Việt và tiếng Anh
`Views`, `ViewModels`	Giao diện Razor và các ViewModel, DTO của API
`wwwroot`	Theme `portal.css`, mã JavaScript (AJAX), thư mục ảnh bìa tải lên
`Database/01_TaoDatabase.sql`	Script tạo database và 17 bảng

Kiến trúc tổng thể

Hệ thống theo mô hình **MVC** của ASP.NET Core. Yêu cầu của trình duyệt đi qua chuỗi middleware (HTTPS, header bảo mật, tệp tĩnh, ngôn ngữ, session, xác thực, phân quyền), tới controller phù hợp; controller gọi tầng dịch vụ dùng chung rồi truy cập dữ liệu qua Entity Framework Core, và trả về view Razor hoặc JSON. Khu quản trị đặt trong **Area `Admin`** để tách khỏi phần còn lại.



Hình 3.1. Kiến trúc tổng thể của hệ thống

Hai điểm thiết kế đáng chú ý: (1) **quy tắc nghiệp vụ nằm ở tầng dịch vụ** (`LoanRules`, `BookQueries`, `CodeGenerator`, `BarcodeGenerator`) nên khu quản trị, khu khách hàng và REST API cùng dùng một nguồn quy tắc; (2) **ViewModel và DTO** được dùng thay cho việc đưa trực tiếp entity ra giao diện, để kiểm soát dữ liệu nhận vào và trả ra.

Phân trang (Paging)

Phân trang thực hiện ở máy chủ bằng `Skip` và `Take`, nên chỉ nạp từ cơ sở dữ liệu đúng số dòng của trang hiện tại. Số trang được chặn trong khoảng hợp lệ. Thành phần phân trang `_Pager` dùng chung cho các danh sách và giữ nguyên các tham số lọc khi chuyển trang.

Lọc và tìm kiếm (Filtering)

Logic tìm kiếm được gom vào một phương thức mở rộng duy nhất `Search`, kết hợp từ khóa (tên sách, ISBN, tác giả), thể loại, "chỉ sách còn mượn được" và sắp xếp. Trang web và REST API cùng gọi phương thức này nên kết quả luôn giống nhau. Khu quản trị còn lọc khách theo tình trạng thẻ (còn hạn, sắp hết hạn, hết hạn, chưa có thẻ, bị khóa) và lọc giao dịch theo khoảng ngày, loại, hình thức, trạng thái.

Annotation

Việc kiểm tra dữ liệu nhập dùng Data Annotations đặt trực tiếp trên model và ViewModel: bắt buộc, độ dài, khoảng giá trị, biểu thức chính quy cho số điện thoại, tên hiển thị. Kiểm tra chạy ở cả trình duyệt (jQuery Validation, nhờ các thuộc tính `data-val`) và ở máy chủ (`ModelState.IsValid`). Các quy tắc không biểu diễn được bằng annotation (ISBN trùng, số điện thoại trùng, kích thước ảnh) được kiểm tra thêm trong controller.

Session

Giỏ sách quan tâm lưu trong session: danh sách mã sách được tuần tự hóa thành JSON, tối đa 20 sách, mất khi hết phiên (30 phút không hoạt động) hoặc khi xóa cookie session. Cookie session được đặt `HttpOnly`. Số sách trong giỏ hiển thị thành huy hiệu trên thanh điều hướng.

Cookie

Hệ thống dùng ba loại cookie: cookie đăng nhập của Identity; cookie `recent_books` ghi nhớ sách xem gần đây (30 ngày); cookie ngôn ngữ của `RequestLocalizationMiddleware`. Cookie do người dùng sửa được nên giá trị đọc vào luôn được kiểm tra (chỉ nhận số nguyên dương). Các cookie đều đặt `HttpOnly` và `SameSite=Lax`.

REST API

API được viết bằng `[ApiController]` trong thư mục `Controllers/Api`, trả về DTO (không trả trực tiếp entity). Có giới hạn `pageSize` tối đa 50, trả `404` cho tài nguyên không có, lỗi nghiệp vụ trả `409` kèm `ProblemDetails`.

Danh mục các điểm cuối (endpoint) của REST API:

API tuân theo các nguyên tắc REST: địa chỉ là danh từ, dùng đúng động từ HTTP, trả mã trạng thái có ý nghĩa, dữ liệu dạng JSON, lỗi theo chuẩn **ProblemDetails** (RFC 7807), danh sách có thông tin phân trang.

Bảng 3.3. Danh mục REST API

Phương thức, địa chỉ	Chức năng	Mã trả về
GET `/api/books`	Danh sách sách: `q`, `categoryId`, `availableOnly`, `sort` (`title` hoặc `new`), `page`, `pageSize` (tối đa 50). Kết quả có `items`, `page`, `pageSize`, `totalItems`, `totalPages`.	200
GET `/api/books/{id}`	Chi tiết một đầu sách.	200, 404
GET `/api/categories`	Thể loại kèm số đầu sách.	200
GET `/api/me/loans`	Sách đang mượn của chính mình (role User).	200, 401, 403
POST `/api/me/loans/{id}/renew`	Gia hạn một cuốn; cần token chống CSRF trong header `RequestVerificationToken`.	200, 400, 401, 404, 409

Với địa chỉ `/api`, khi chưa đăng nhập hệ thống trả **401** (hoặc **403** nếu sai vai trò) thay vì chuyển hướng sang trang đăng nhập, để mã JavaScript xử lý được kết quả.

AJAX

Hai chức năng dùng AJAX (jQuery) gọi chính REST API: (1) **tìm kiếm sách tức thì** ở trang tra cứu, chờ 300 ms sau lần gõ cuối rồi gọi `GET /api/books`, và chỉ nhận kết quả của lần gọi mới nhất; (2) **gia hạn** ở trang sách đang mượn, gọi `POST /api/me/loans/{id}/renew` rồi cập nhật ngày hạn, số lần gia hạn và thông báo tại chỗ. Nếu JavaScript bị tắt, form vẫn hoạt động nhờ trang do máy chủ dựng sẵn. Mọi dữ liệu chèn vào HTML đều được mã hóa để chống XSS.

Bảo mật (Security)

Bảng 3.4. Các biện pháp bảo mật đã áp dụng

Nguy cơ	Biện pháp trong hệ thống
Lộ mật khẩu	ASP.NET Core Identity băm mật khẩu; không lưu mật khẩu dạng rõ.
Truy cập trái quyền	`[Authorize(Roles = ...)]` trên toàn bộ controller khu quản trị và khu khách hàng; chưa đăng nhập bị chuyển hướng; sai vai trò bị từ chối.
Truy cập chéo dữ liệu (IDOR)	Khu khách hàng không nhận mã khách từ URL hay form, luôn lấy hồ sơ từ tài khoản đang đăng nhập; gia hạn kiểm tra sách thuộc đúng khách, nếu không trả 404.
Chiếm hồ sơ khi đăng ký	Liên kết với hồ sơ có sẵn phải khớp cả mã thành viên và số điện thoại; chỉ biết số điện thoại thì bị từ chối.
Dò mật khẩu	Khóa tài khoản 5 phút sau 5 lần đăng nhập sai; thông báo lỗi chung không lộ email đã đăng ký; tài khoản bị vô hiệu hóa không đăng nhập được.
CSRF	Mọi thao tác ghi dữ liệu là POST có anti-forgery token; AJAX gửi token qua header `RequestVerificationToken`.
XSS	Razor tự mã hóa đầu ra; mã JavaScript mã hóa dữ liệu khi dựng HTML; Content-Security-Policy giới hạn nguồn nội dung.
SQL injection	Mọi truy vấn qua Entity Framework Core là truy vấn tham số hóa; không nối chuỗi SQL.
Tải tệp nguy hiểm	Chỉ nhận .jpg, .jpeg, .png, .webp, tối đa 2 MB; tên tệp lưu là GUID do máy chủ sinh.
Chuyển hướng ra ngoài	Mọi `returnUrl` được kiểm tra `IsLocalUrl` trước khi chuyển hướng.
Giả mạo số tiền từ trình duyệt	Máy chủ tính lại phí thuê, phạt từ dữ liệu trong cơ sở dữ liệu, không tin số gửi lên.
Nhúng trang, đoán kiểu nội dung	Header `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Referrer-Policy`, `Content-Security-Policy`.
Lộ cookie	Cookie đăng nhập và session `HttpOnly`, `SameSite=Lax`; hết hạn trượt sau 8 giờ.

Quốc tế hóa (Internationalization)

Giao diện công khai và khu khách hàng hỗ trợ **tiếng Việt (mặc định)** và **tiếng Anh**. Chuỗi giao diện nằm trong file tài nguyên `Resources/SharedResource.resx` và `SharedResource.en.resx` (214 khóa), được lấy bằng lớp `Loc` trong view (`@T["nav.home"]`). Người dùng chọn ngôn ngữ bằng nút VI/EN, lựa chọn lưu trong

cookie. Ngày và số được định dạng theo ngôn ngữ đang chọn. Thông báo kiểm tra dữ liệu (Data Annotations), thông báo từ máy chủ và lỗi từ API cũng được dịch; chuỗi dùng trong JavaScript được truyền qua đối tượng `window.I18N`. Khu quản trị giữ tiếng Việt (ghi nhận là hạn chế ở mục 5.1).

Kiểm tra điều kiện mượn

Toàn bộ điều kiện được gom ở lớp `LoanRules` để khu quản trị, khu khách hàng và REST API dùng chung. Kết quả là danh sách lý do chặn (`Blockers`); được mượn khi danh sách rỗng.

Tính tiền khi trả sách

Số tiền luôn được tính lại ở máy chủ từ dữ liệu trong cơ sở dữ liệu. Giao diện chỉ hiển thị bản xem trước bằng JavaScript cho tiện, còn số liệu ghi sổ là số do máy chủ tính.

Bảng 3.5. Các khoản thu theo từng trường hợp trả sách

Trường hợp	Các khoản thu	Bản sao chuyển sang
Trả bình thường	Phí thuê + phạt trễ (nếu có)	Sẵn sàng
Sách hỏng	Phí thuê + phạt trễ + tiền đền	Hỏng
Sách mất	Chỉ tiền đền	Mất

Chống mượn trùng và kiểm soát đồng thời

Hai Admin có thể cùng lúc nhập một mã vạch. Để không bao giờ có hai dòng mượn chưa trả của cùng một bản sao, hệ thống dùng hai lớp bảo vệ: **chỉ mục duy nhất có điều kiện** ở cơ sở dữ liệu và **`RowVersion`** của bản sao. Phiếu mượn và việc đổi trạng thái bản sao được lưu trong một giao dịch; nếu lỗi, người dùng nhận thông báo và có thể thử lại.

Bán thẻ, cọc và hoàn cọc

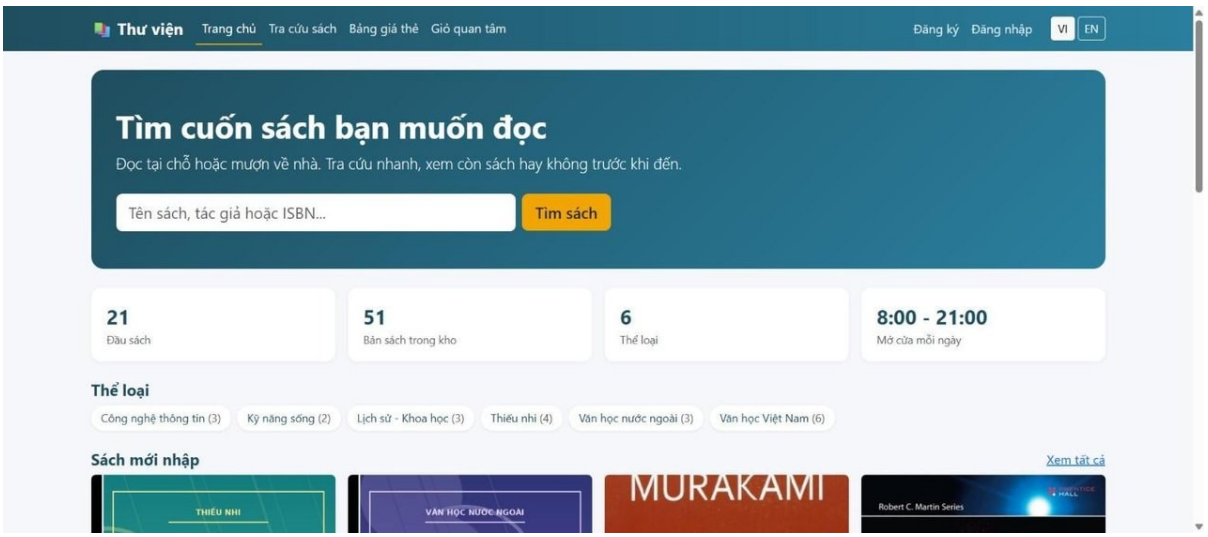
Thẻ và các biên lai (phí thẻ, tiền cọc) được thêm vào cùng một lần `SaveChanges`, nên cùng thành công hoặc cùng thất bại. Tiền cọc chỉ thu khi khách chưa giữ cọc nào. Hoàn cọc chỉ thực hiện khi khách không còn sách chưa trả và không nợ; hệ thống ghi một dòng thanh toán số âm, chuyển mọi thẻ của khách sang Đã hủy và các khoản cọc sang Đã hoàn. Doanh thu **không** gồm tiền cọc (là tiền giữ hộ), được tách riêng ở bảng điều khiển và báo cáo.

3.2. Mô tả kết quả đạt được bằng cách dán các hình ảnh và giải thích về từng chức năng trong hệ thống

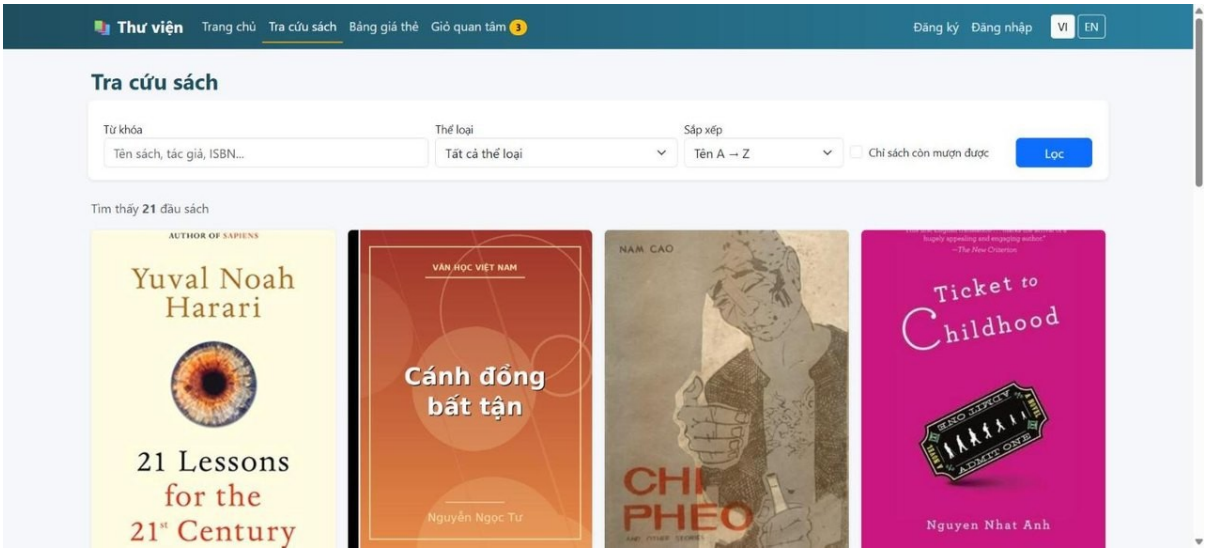
Các mục dưới đây mô tả từng chức năng kèm ảnh chụp màn hình của hệ thống.

Trang chủ và tra cứu sách (công khai)

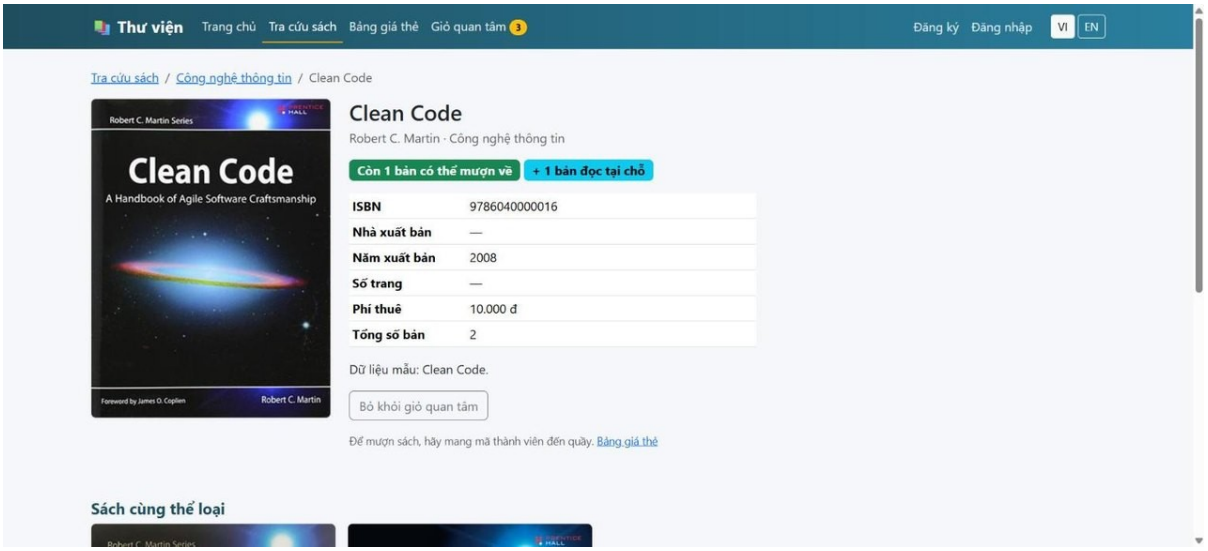
Trang chủ giới thiệu thư viện với ô tìm kiếm lớn, số liệu tổng quan, thể loại, sách mới nhập và mục “Bạn đã xem gần đây” đọc từ cookie. Trang tra cứu cho phép tìm theo tên, tác giả, ISBN, lọc theo thể loại, chọn chỉ sách còn mượn được, sắp xếp; kết quả cập nhật tức thì bằng AJAX và có nút “Xem thêm”.



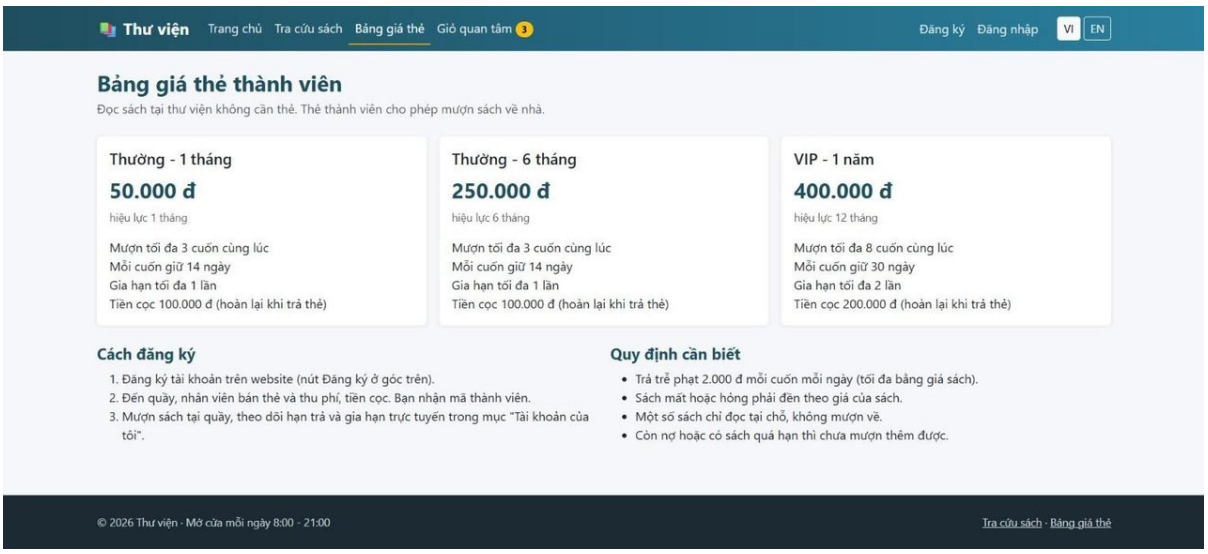
Hình 3.2. Trang chủ của website



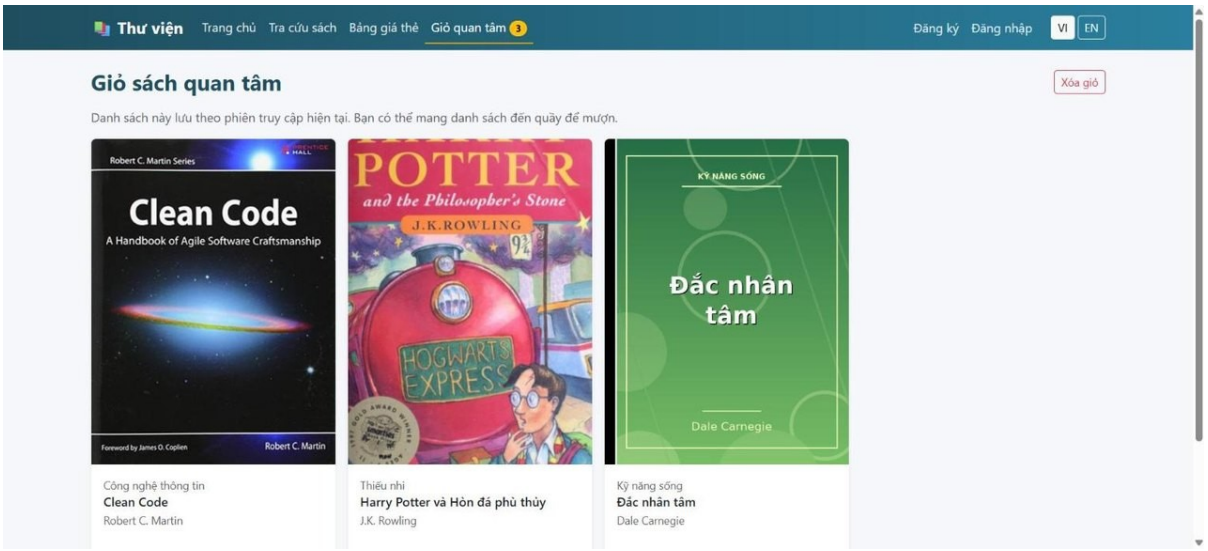
Hình 3.3. Trang tra cứu sách



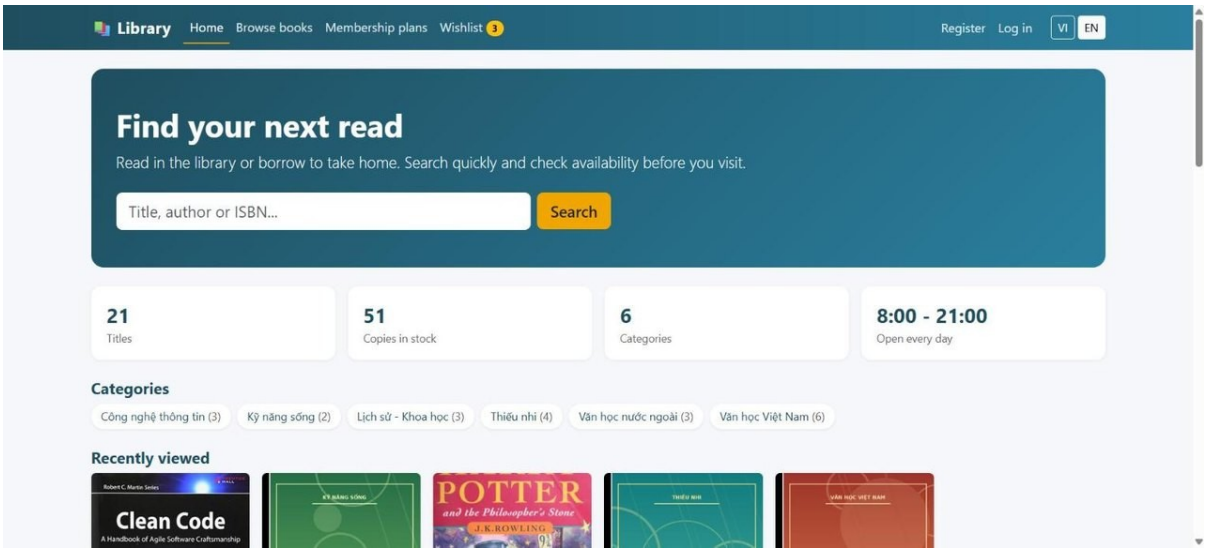
Hình 3.4. Trang chi tiết sách



Hình 3.5. Bảng giá thẻ thành viên



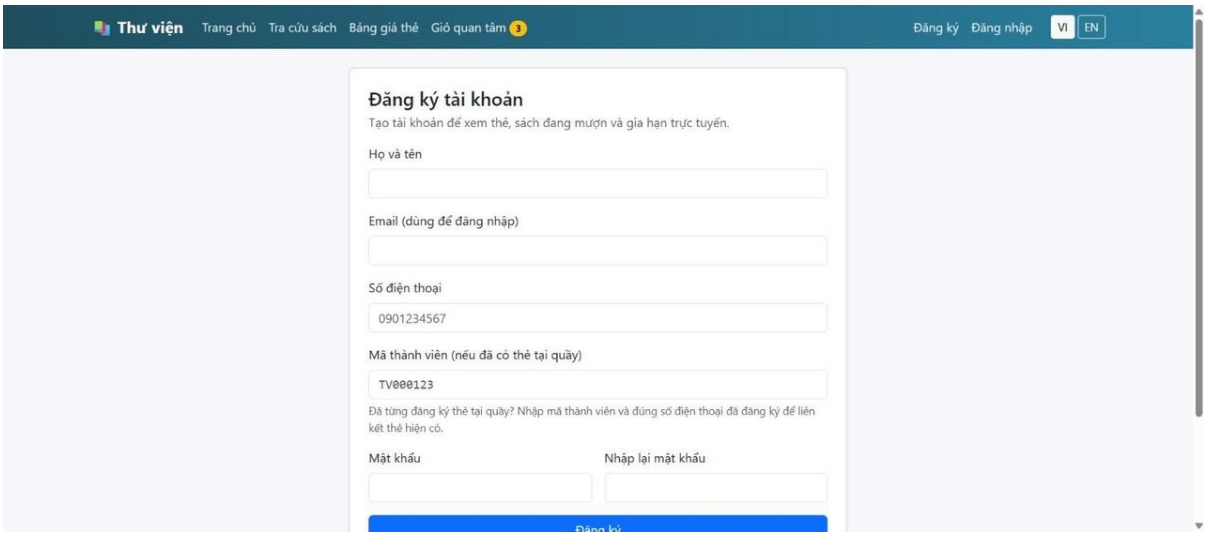
Hình 3.6. Giỏ sách quan tâm lưu trong Session



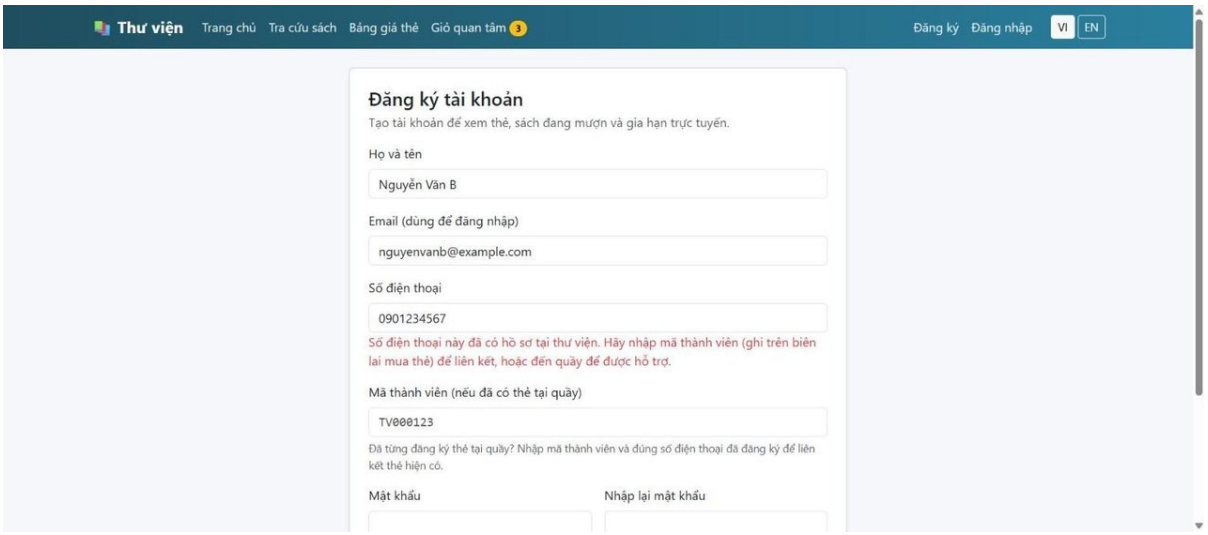
Hình 3.7. Giao diện tiếng Anh

Đăng ký và đăng nhập

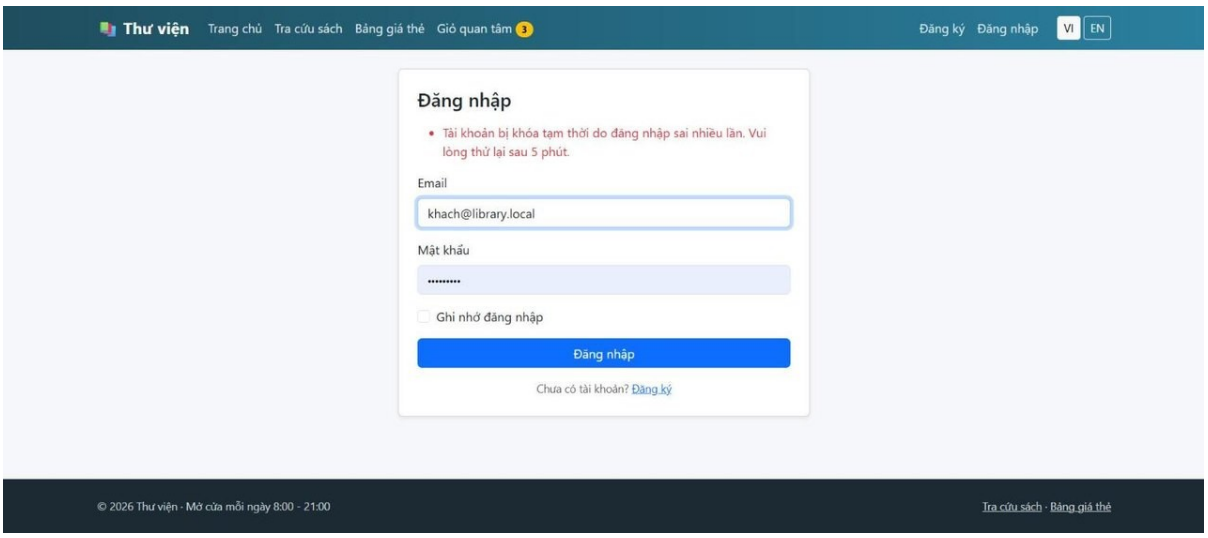
Khách đăng ký tài khoản; hệ thống tự gán vai trò User và tạo hoặc liên kết hồ sơ thành viên. Nếu số điện thoại đã có hồ sơ tại quầy, khách phải nhập mã thành viên để liên kết. Đăng nhập sai nhiều lần thì tài khoản bị khóa tạm thời. Sau khi đăng nhập, Admin vào khu quản trị, khách hàng vào "Tài khoản của tôi".



Hình 3.8. Trang đăng ký tài khoản



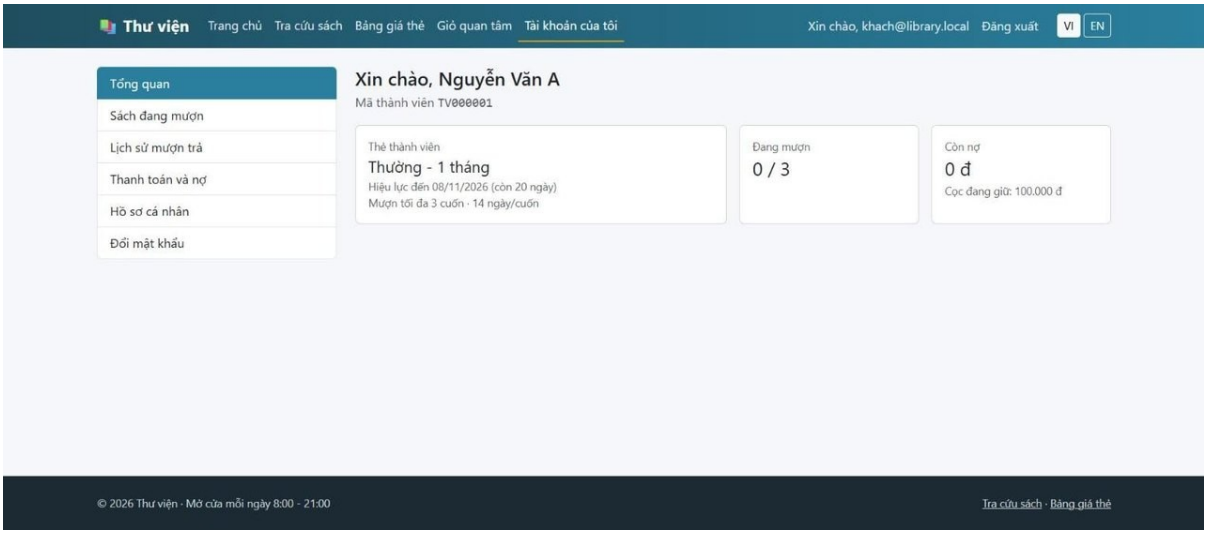
Hình 3.9. Chặn chiếm hồ sơ bằng số điện thoại



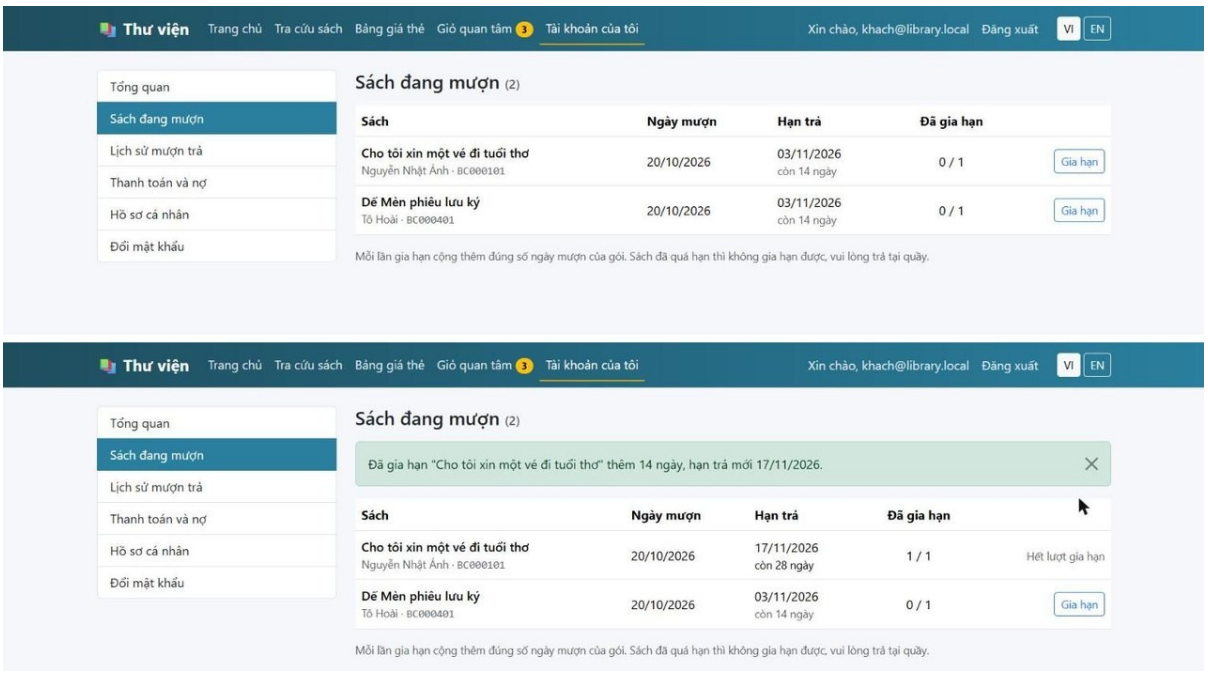
Hình 3.10. Khóa tài khoản khi đăng nhập sai nhiều lần

Khu vực khách hàng

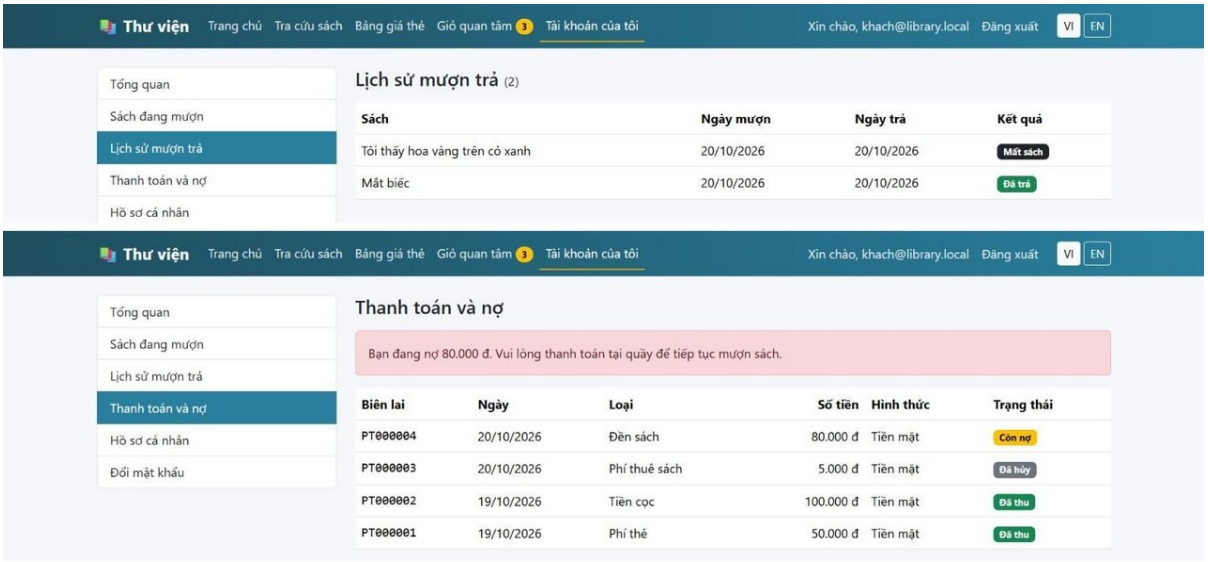
Khách xem tổng quan thẻ, hạn thẻ, số sách đang mượn, khoản nợ, tiền cọc và lý do chưa mượn được (nếu có); xem sách đang mượn kèm số ngày còn lại hoặc quá hạn; gia hạn bằng AJAX; xem lịch sử mượn trả, lịch sử thanh toán và cập nhật hồ sơ.



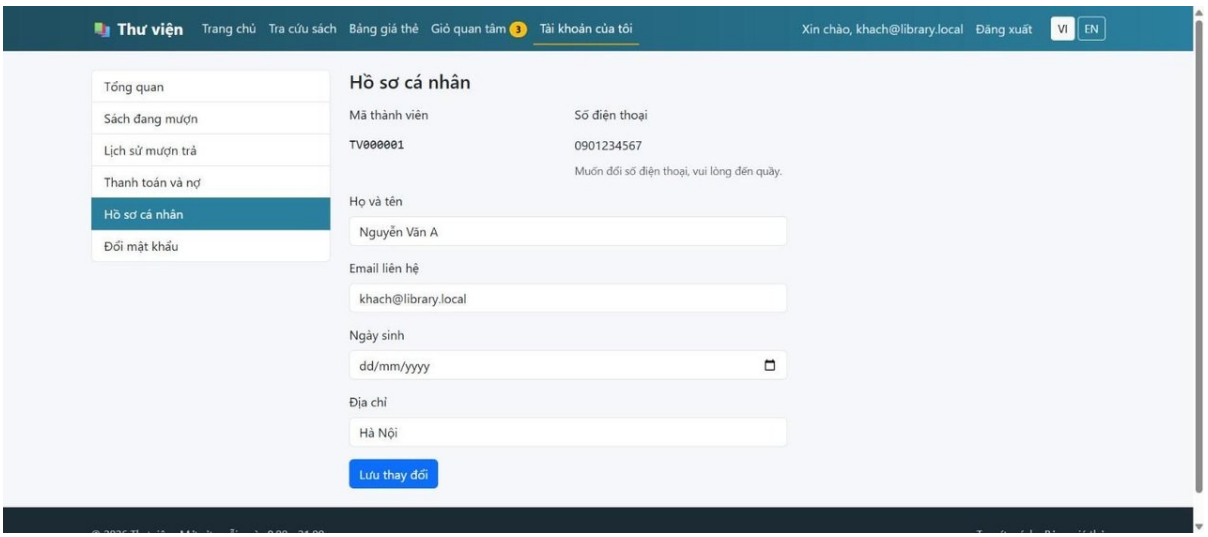
Hình 3.11. Tổng quan tài khoản khách hàng



Hình 3.12. Gia hạn sách trực tuyến bằng AJAX



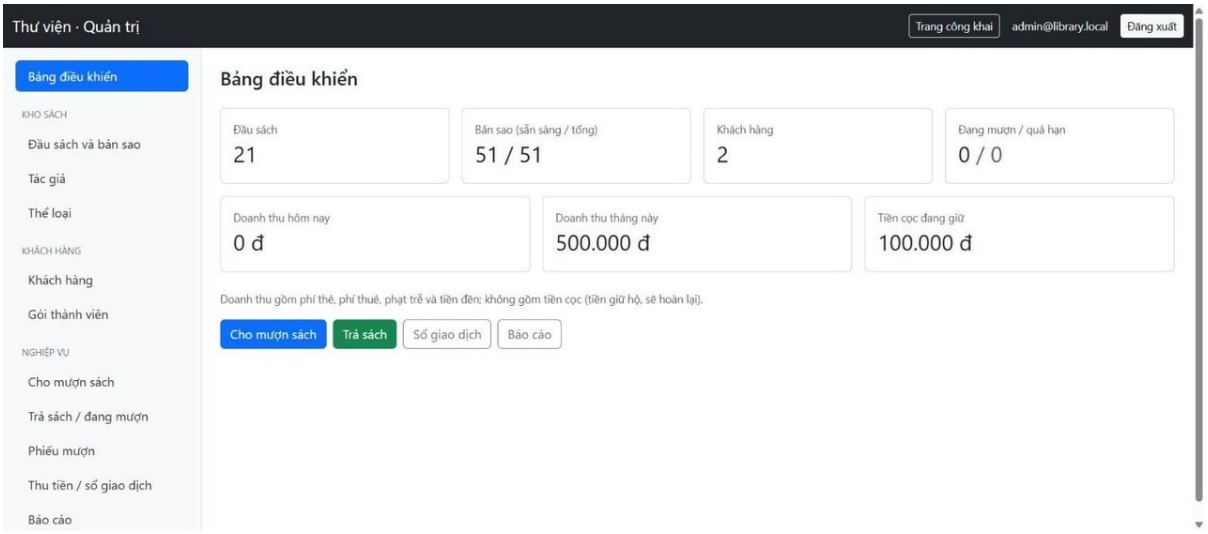
Hình 3.13. Lịch sử mượn trả và thanh toán



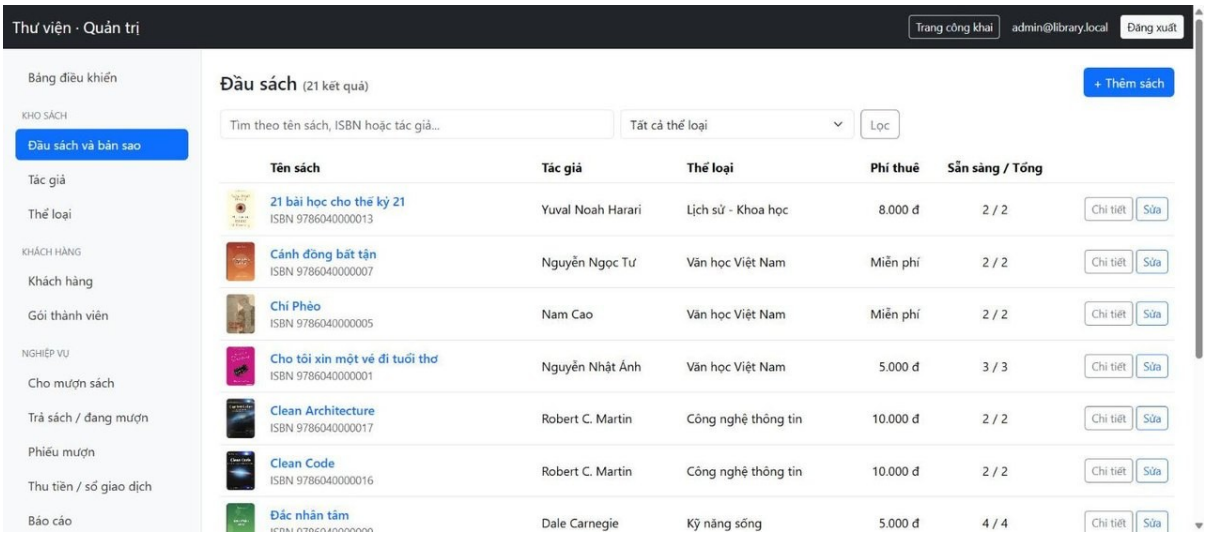
Hình 3.14. Hồ sơ cá nhân của khách hàng

Bảng điều khiển và quản lý kho sách (Admin)

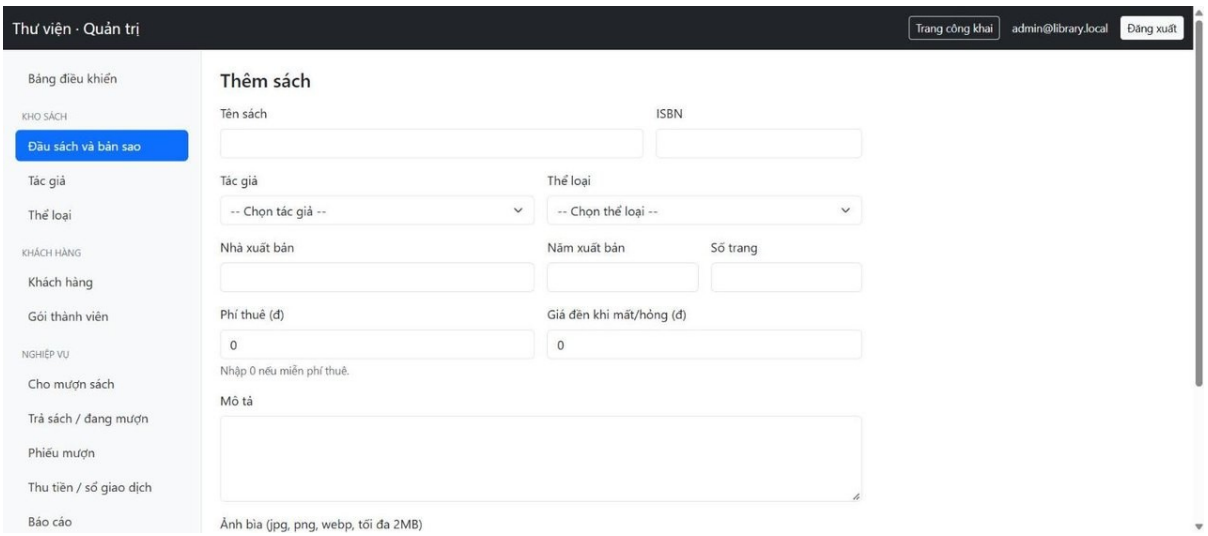
Bảng điều khiển hiển thị số đầu sách, số bản sao, số khách, sách đang mượn và quá hạn, doanh thu hôm nay và tháng này, tiền cọc đang giữ. Kho sách có tìm kiếm, lọc theo thể loại, phân trang; thêm sách kèm ảnh bìa (kiểm tra định dạng và kích thước), tự sinh mã vạch cho bản sao; trang chi tiết sách quản lý các bản sao.



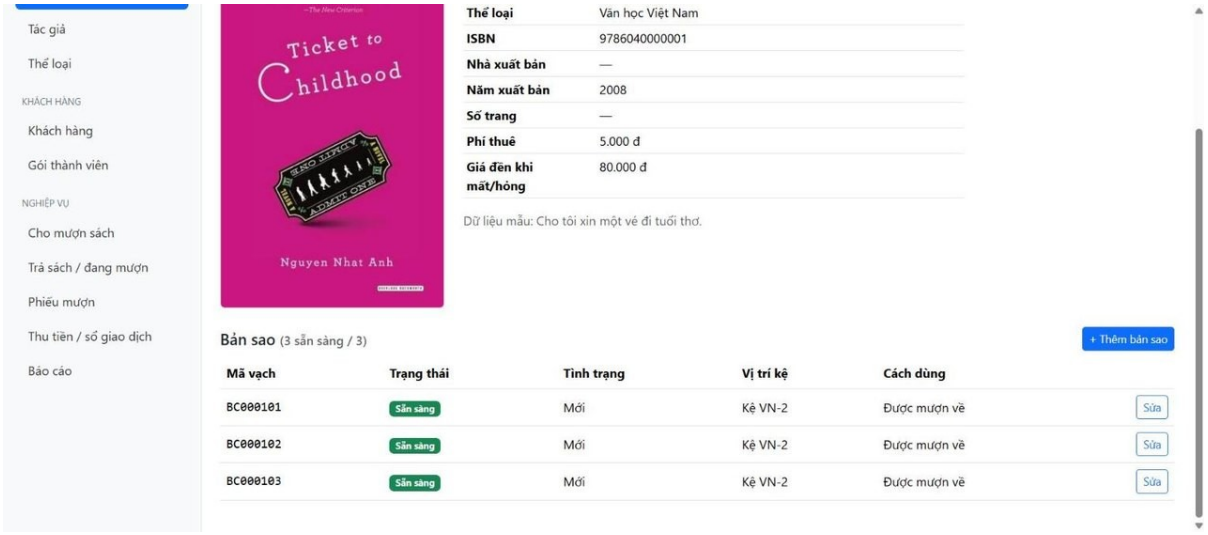
Hình 3.15. Bảng điều khiển quản trị



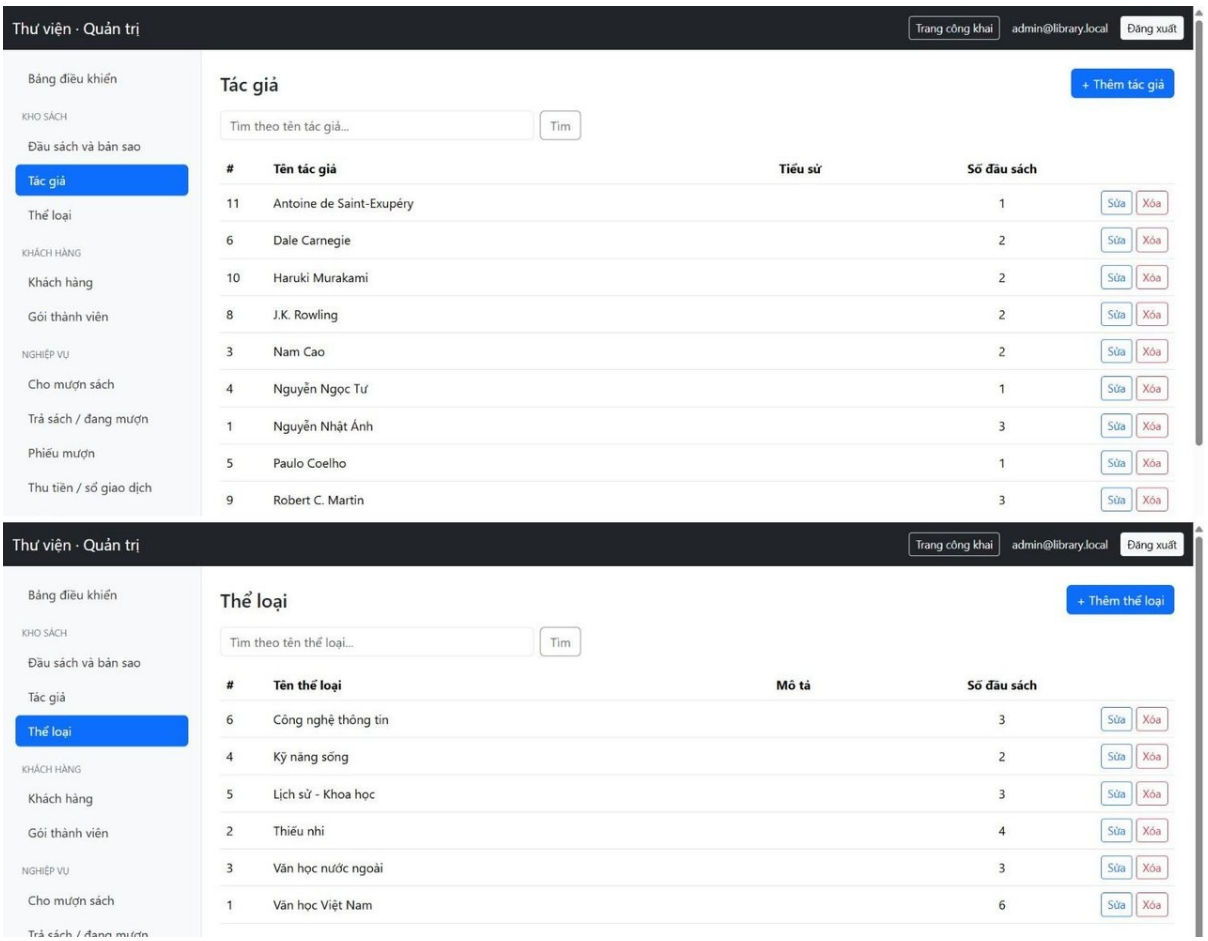
Hình 3.16. Danh sách đầu sách



Hình 3.17. Thêm sách và tải ảnh bìa



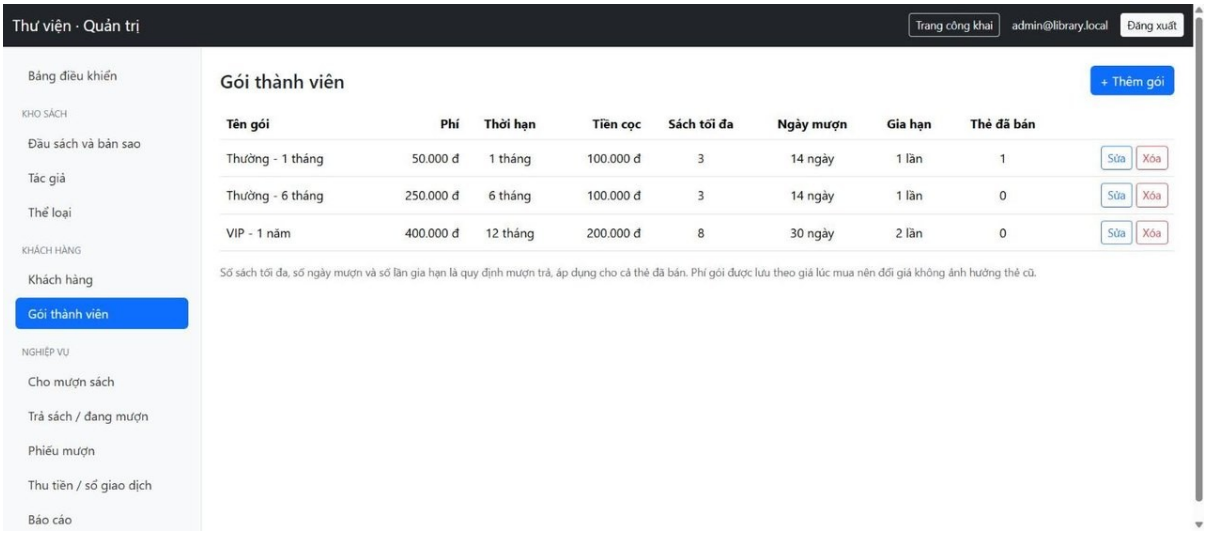
Hình 3.18. Quản lý bản sao của một đầu sách



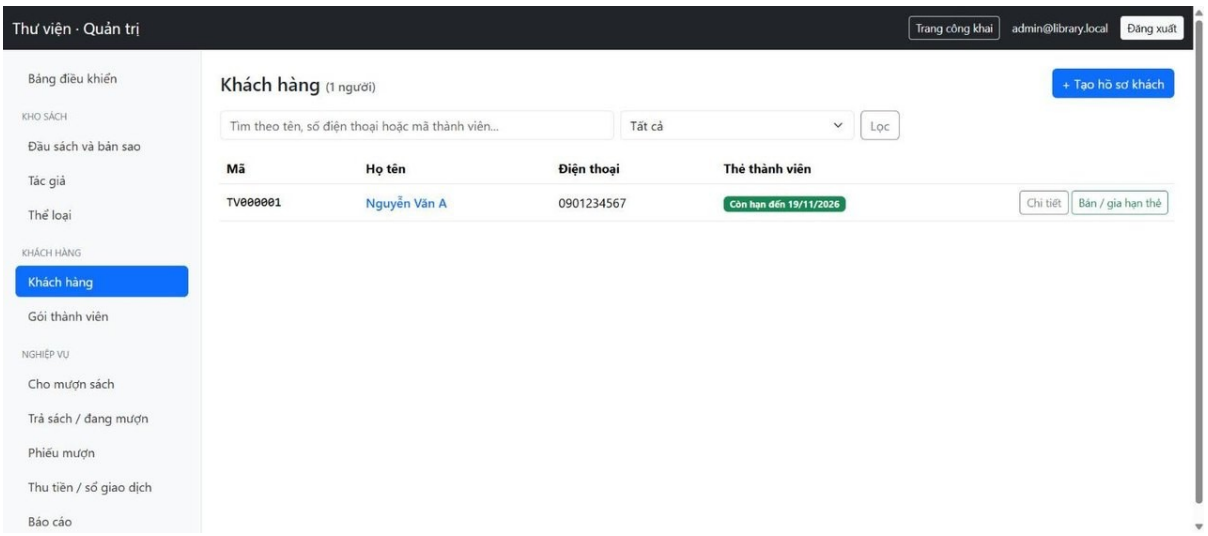
Hình 3.19. Quản lý tác giả và thể loại

Gói thẻ và khách hàng

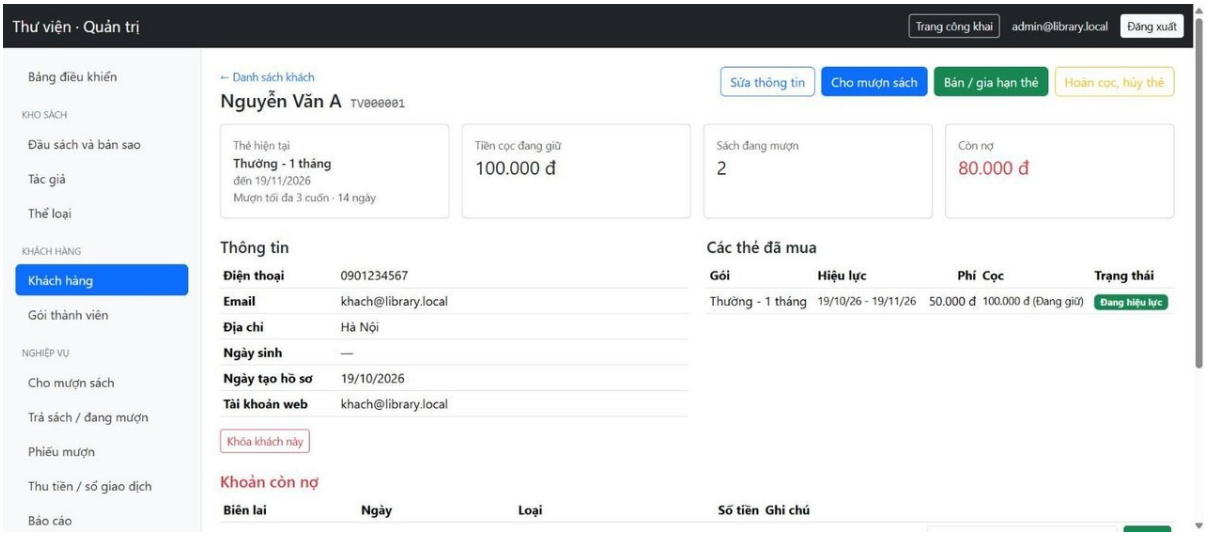
Admin quản lý các gói thẻ, tạo hồ sơ khách, tìm và lọc khách theo tình trạng thẻ. Trang chi tiết khách tổng hợp thẻ hiện tại, tiền cọc, sách đang mượn, khoản nợ, lịch sử thẻ và giao dịch. Bán thẻ hiển thị tổng thu (phí và cọc); hoàn cọc ghi giao dịch số âm.



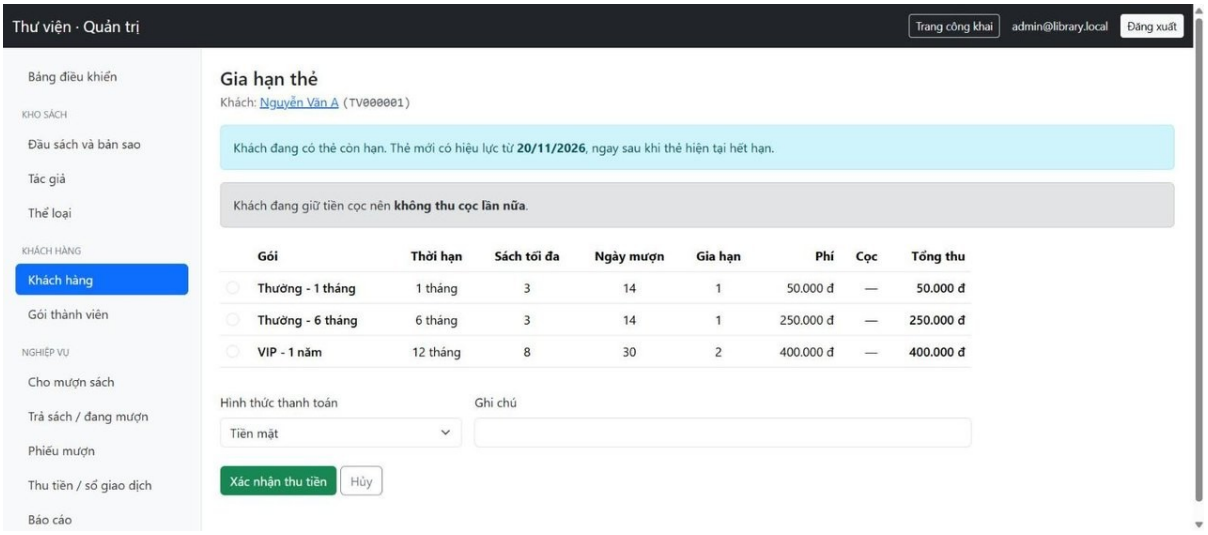
Hình 3.20. Quản lý gói thành viên



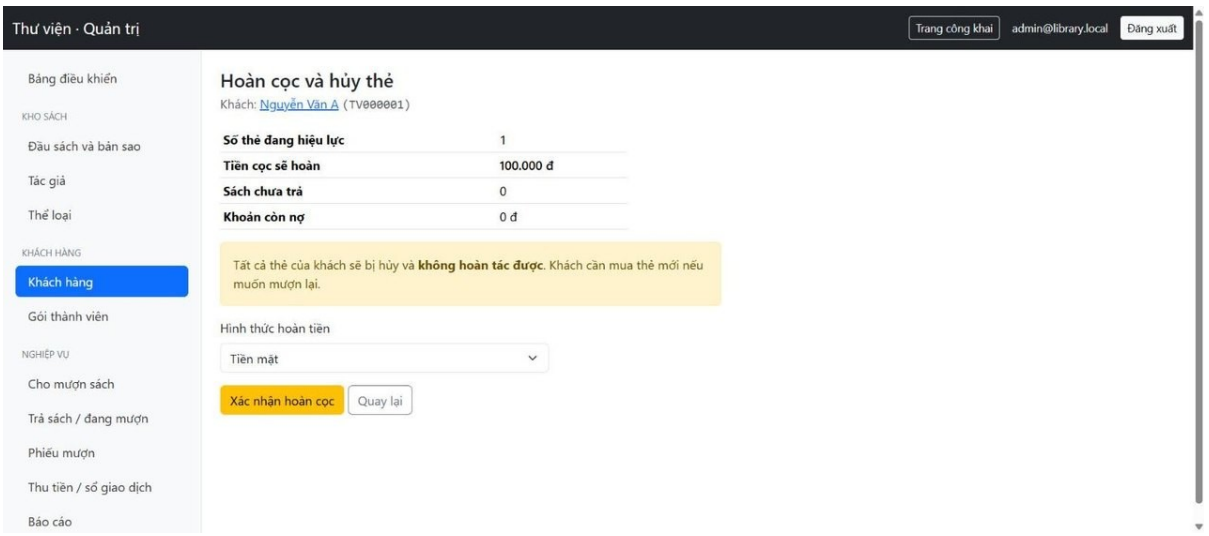
Hình 3.21. Danh sách khách hàng



Hình 3.22. Chi tiết khách hàng



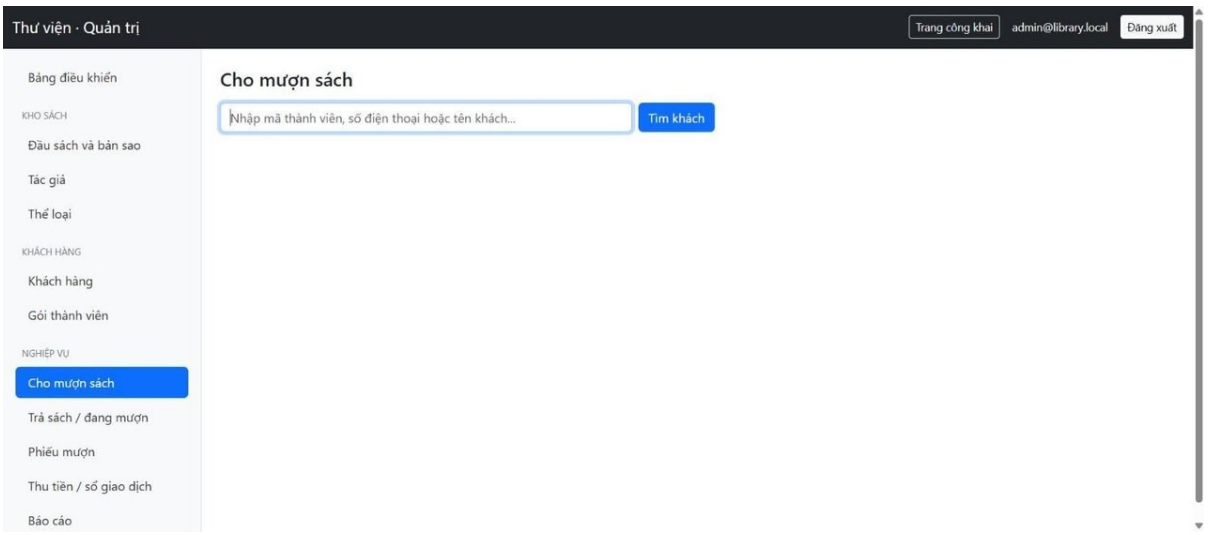
Hình 3.23. Bán và gia hạn thẻ



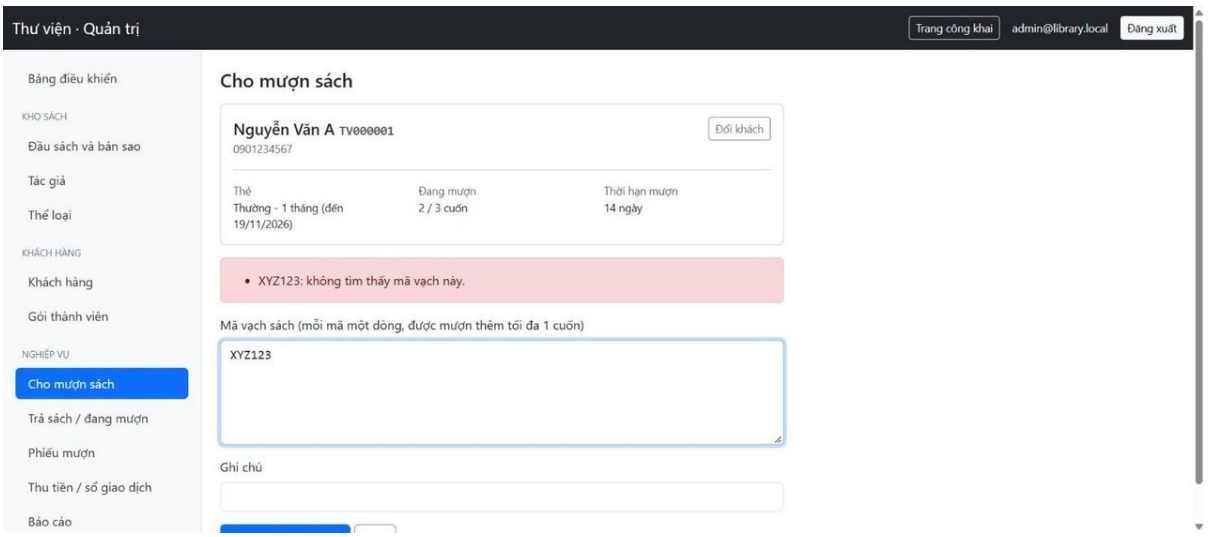
Hình 3.24. Hoàn cọc và hủy thẻ

Mượn, trả, gia hạn

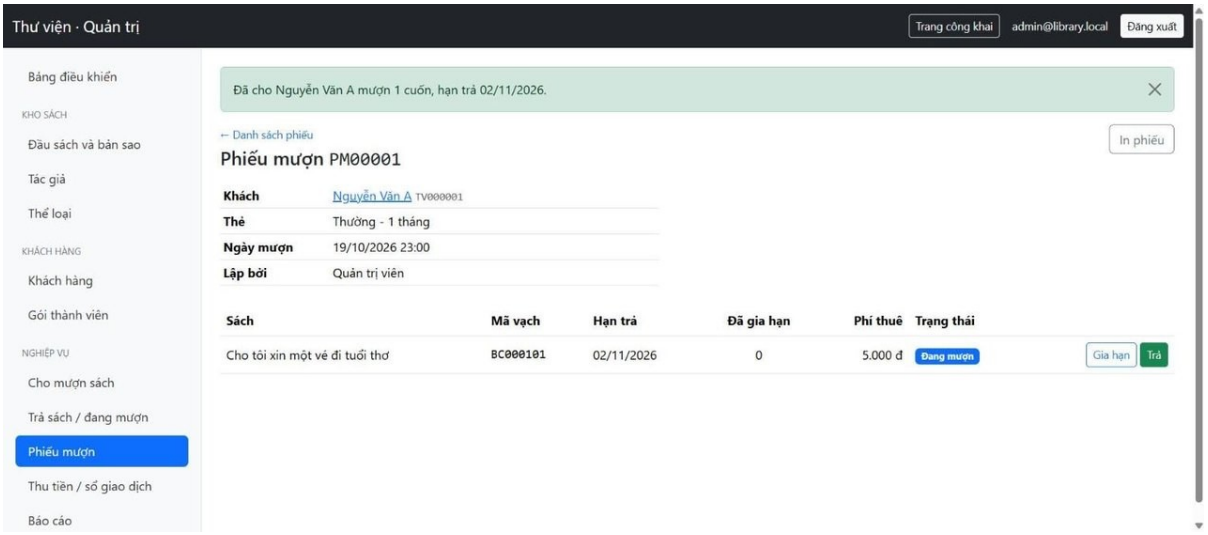
Màn hình cho mượn tìm khách, hiển thị điều kiện và nhập mã vạch từng dòng; mọi lỗi hiển thị theo từng mã. Phiếu mượn có thể in. Màn hình trả sách cho quét mã vạch hoặc chọn từ danh sách sách đang mượn (lọc, chỉ quá hạn); trang xác nhận tính sẵn phí thuê, phạt trễ và tổng tiền thay đổi theo lựa chọn bình thường, hỏng, mất. Khoản ghi nợ được thu ở hồ sơ khách.



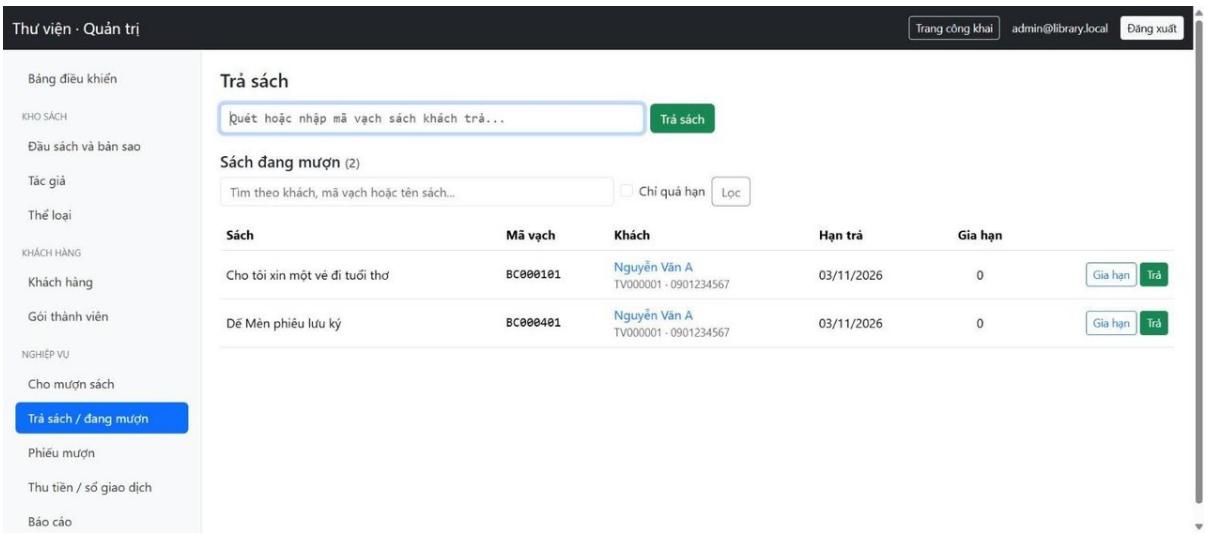
Hình 3.25. Màn hình cho mượn sách tại quầy (bước tìm khách)



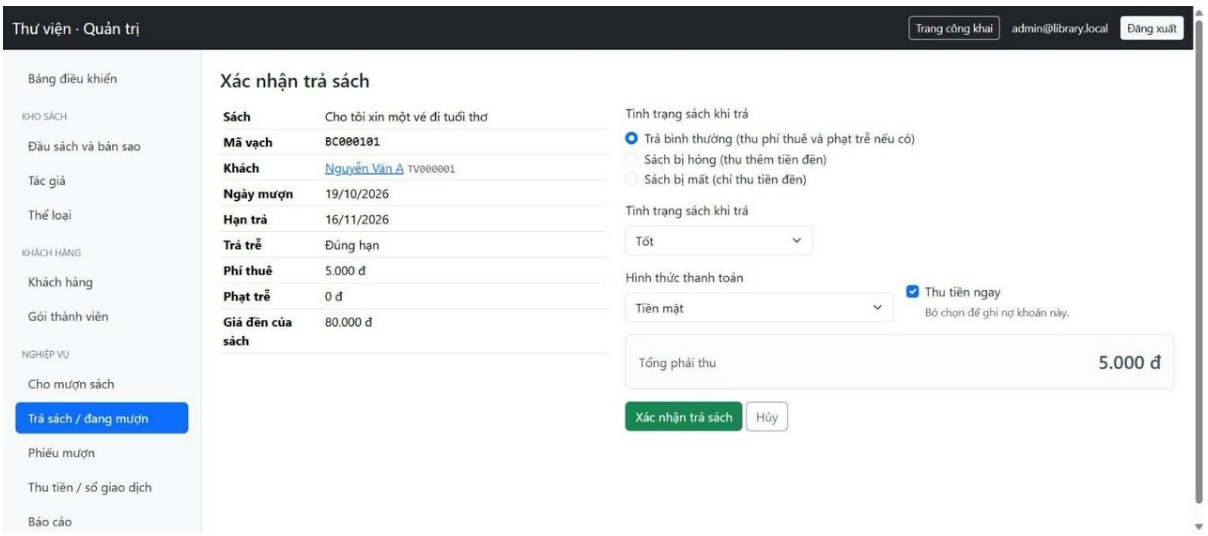
Hình 3.26. Kiểm tra điều kiện mượn



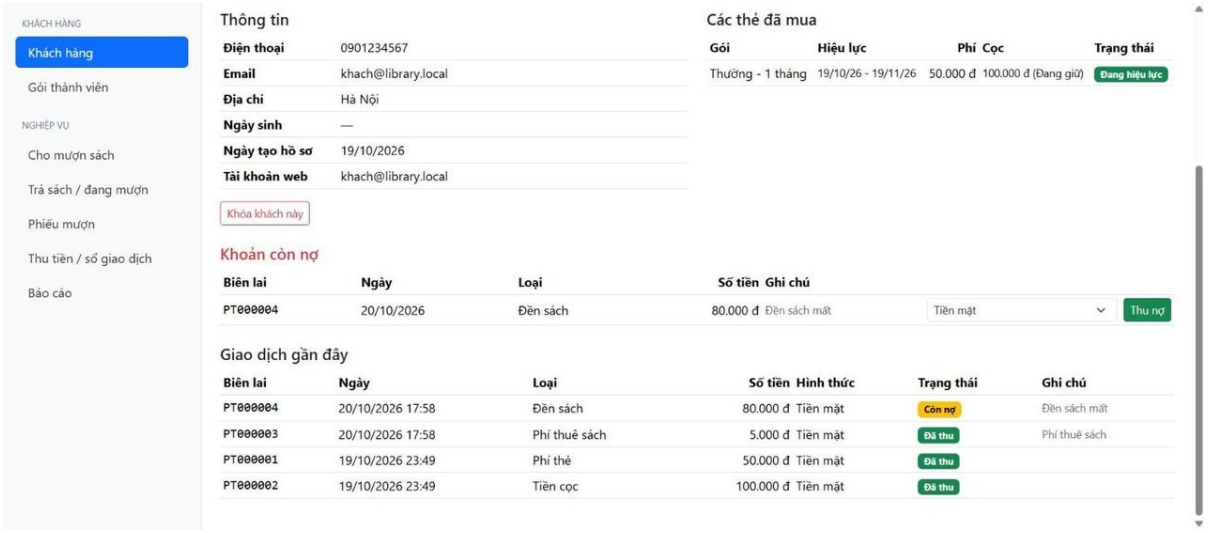
Hình 3.27. Phiếu mượn



Hình 3.28. Danh sách sách đang mượn



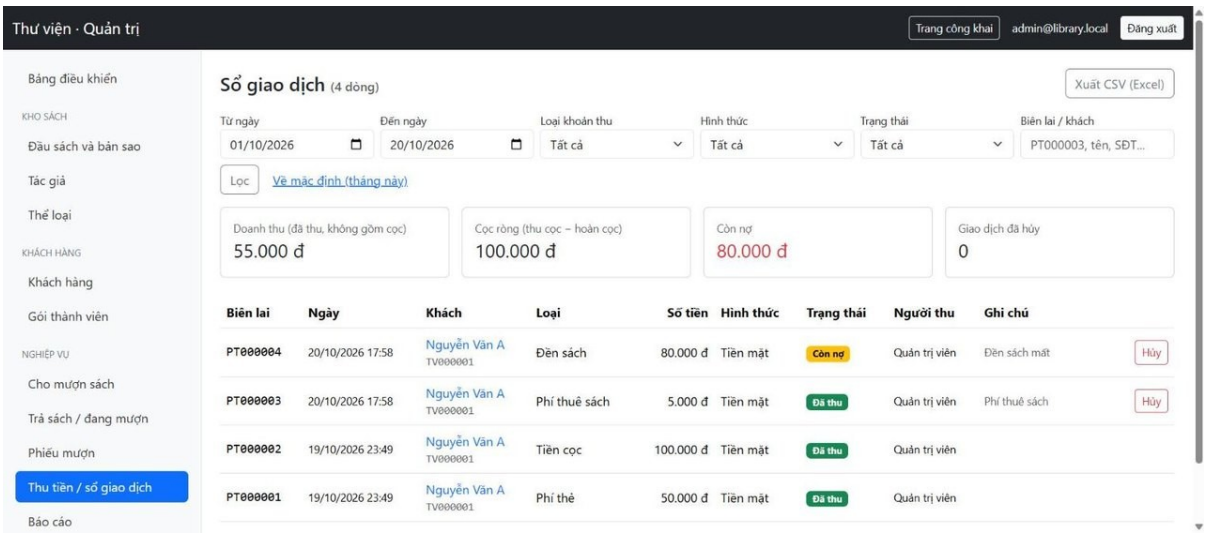
Hình 3.29. Xác nhận trả sách và tính phạt



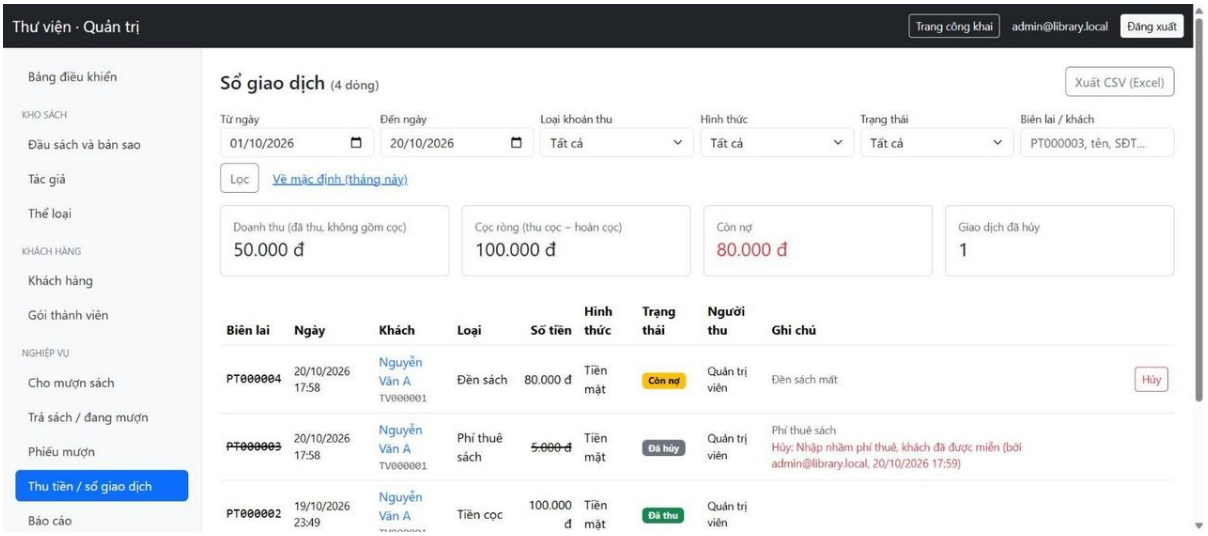
Hình 3.30. Ghi nợ và thu nợ

Sổ giao dịch và báo cáo

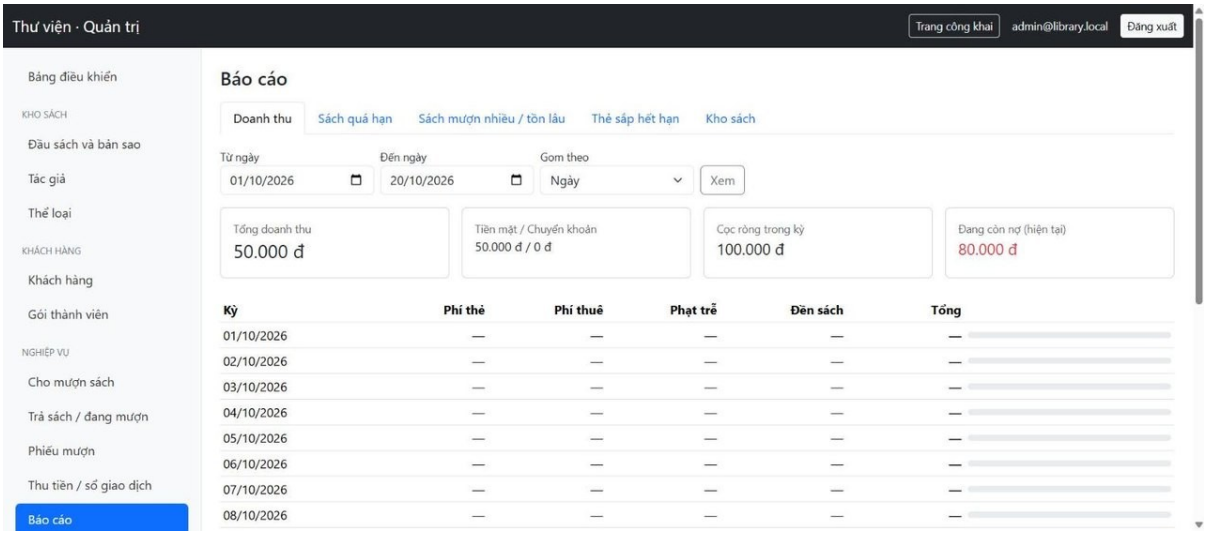
Sổ giao dịch lọc theo khoảng ngày, loại, hình thức, trạng thái và từ khóa, có bốn thẻ tổng (doanh thu, cọc ròng, còn nợ, số giao dịch hủy) và xuất CSV mở được bằng Excel. Hủy giao dịch bắt buộc có lý do và chỉ áp dụng cho phí thuê, phạt, tiền đền. Năm báo cáo gồm doanh thu theo ngày hoặc tháng, sách quá hạn, sách mượn nhiều và tồn lâu, thẻ sắp hết hạn, thống kê kho sách.



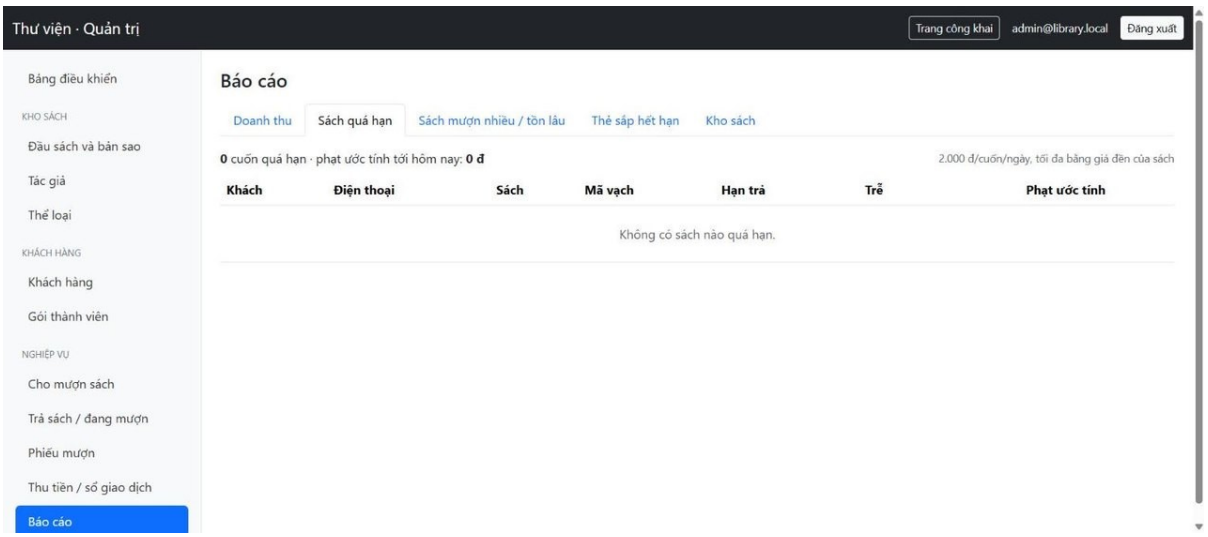
Hình 3.31. Sổ giao dịch



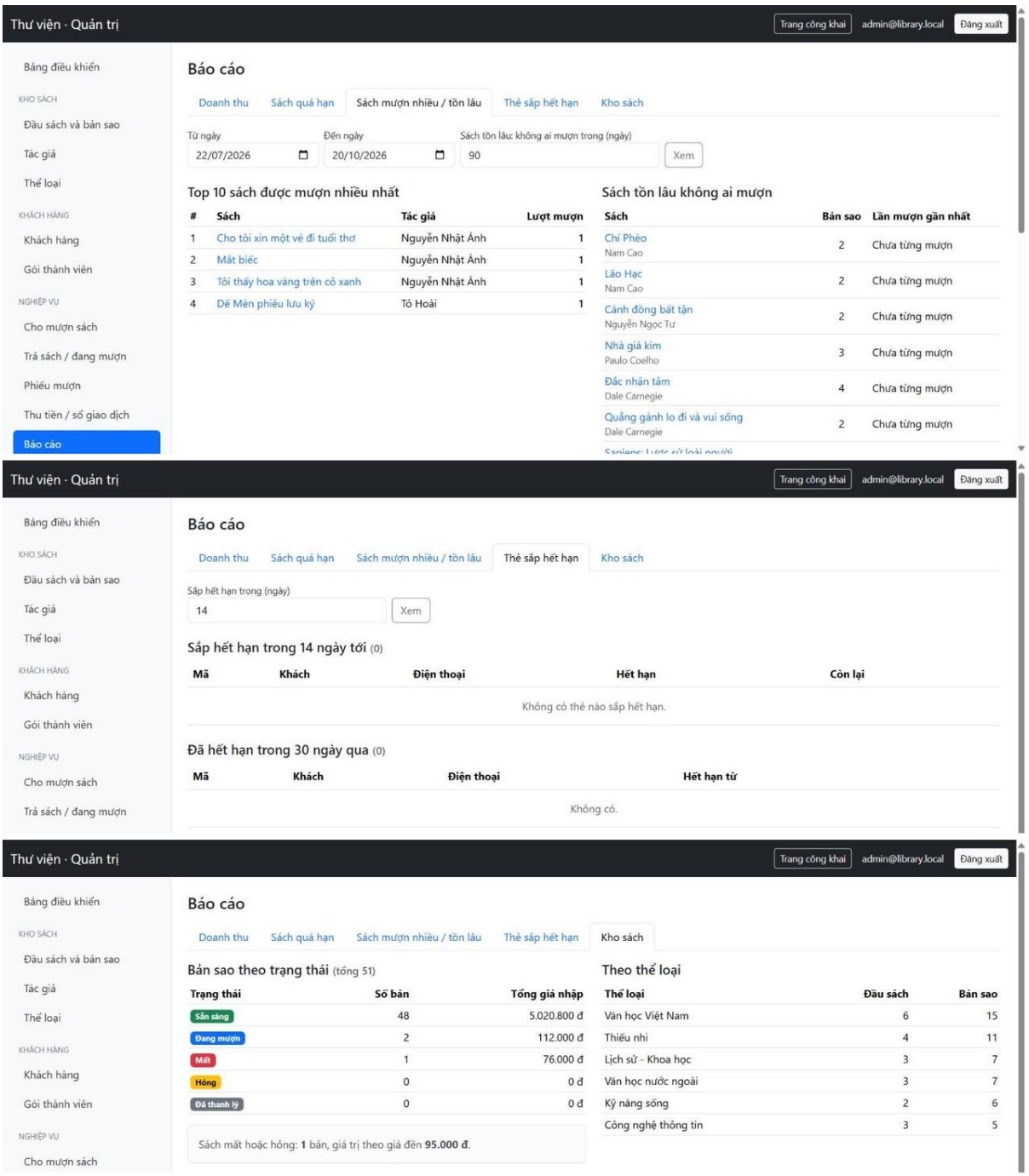
Hình 3.32. Hủy giao dịch có lý do



Hình 3.33. Báo cáo doanh thu



Hình 3.34. Báo cáo sách quá hạn



Hình 3.35. Các báo cáo còn lại

REST API và bảo mật

Kết quả gọi API xem trực tiếp trên trình duyệt: danh sách sách trả về dạng JSON có thông tin phân trang, và tài nguyên không tồn tại trả mã 404 theo chuẩn ProblemDetails. Các cơ chế xác thực, chống CSRF và header bảo mật đã trình bày ở mục 3.1.



Hình 3.36. Kết quả GET /api/books



Hình 3.37. Phản hồi 404 (ProblemDetails) của REST API

CHƯƠNG 4. KIỂM THỬ

4.1. Mục tiêu phát hiện lỗi trong quá trình xây dựng hệ thống

Mục tiêu kiểm thử là **phát hiện lỗi** trong quá trình xây dựng hệ thống và xác nhận hệ thống đáp ứng yêu cầu. Phương pháp là **kiểm thử chức năng hộp đen**: thực hiện các bước như người dùng thật, so sánh kết quả với đầu ra dự kiến. Các test case được xây dựng thành một danh mục có cấu trúc, mỗi test case gồm: mục tiêu, các bước thực hiện, dữ liệu đầu vào và ràng buộc, đầu ra dự kiến, đầu ra thực tế, kết quả pass/fail và (nếu fail) mô tả lỗi cùng đề xuất sửa.

- Các test case được sắp theo nhóm chức năng và có **mức ưu tiên** (Cao, Trung bình, Thấp); nhóm ưu tiên Cao gồm các chức năng cốt lõi và các kiểm tra bảo mật.
- Sau mỗi lần sửa lỗi trong quá trình phát triển, test case liên quan được chạy lại để xác nhận lỗi đã hết và không làm hỏng chức năng khác.
- Các điều kiện khó tạo bằng giao diện (sách quá hạn, thẻ sắp hết hạn, tài khoản bị vô hiệu hóa) được tạo bằng lệnh SQL; kết quả vẫn được kiểm chứng qua giao diện.

Môi trường và dữ liệu kiểm thử

Đợt kiểm thử chính được thực hiện ngày 19/10/2026 trên môi trường phát triển (xem mục 3.1), website chạy tại `https://localhost:7105`, cơ sở dữ liệu nạp dữ liệu mẫu: 21 đầu sách, 51 bản sao, 3 gói thẻ, tài khoản Admin, tài khoản khách mẫu (hồ sơ TV000001). Các test thay đổi dữ liệu được chạy theo thứ tự trong từng nhóm; một số test tạo thêm dữ liệu thử (khách, sách, phiếu mượn, biên lai) và sau khi kiểm thử xong cơ sở dữ liệu được tạo lại từ script để trả về dữ liệu sạch.

4.2. Cách thức: xây dựng danh mục các test case

Mỗi test case trong danh mục có đủ các thành phần theo yêu cầu: **mục tiêu test**; **dữ liệu đầu vào, các ràng buộc**; **đầu ra dự kiến**; **đầu ra thực tế**; **kết quả test pass/fail** và, nếu fail, **đề xuất và mô tả quá trình fix lỗi** (xem mục 4.3).

Danh mục test case

Danh mục gồm **115 test case** chia thành 7 nhóm, trong đó 73 test case ưu tiên Cao. Toàn bộ danh mục (đầy đủ các cột, kèm đầu ra thực tế) nằm trong file `Test-case-thu-vien.xlsx` đính kèm. Phần lớn test được chạy bằng cách gửi các yêu cầu tương đương thao tác trên trình duyệt (biểu mẫu kèm token chống CSRF, lời gọi API) trong phiên đăng nhập thật của website; một số test được thao tác trực tiếp trên giao diện. Bảng dưới đây tổng hợp kết quả theo nhóm.

Bảng 4.1. Tổng hợp kết quả kiểm thử theo nhóm chức năng

Nhóm chức năng	Số test case	Pass	Fail	Chưa test
Đăng nhập, đăng ký, phân quyền (DN)	17	16	1	0
Kho sách (KS)	15	14	0	1
Gói thẻ và khách hàng (KH)	12	11	0	1
Mượn, trả, gia hạn (MT)	22	21	0	1

Nhóm chức năng	Số test case	Pass	Fail	Chưa test
Thu tiền và báo cáo (TT)	13	13	0	0
Cổng công khai, session, cookie, AJAX, API (WEB)	26	23	0	3
Bảo mật và quốc tế hóa (BM)	10	9	0	1
Tổng cộng	115	107	1	7

Các test case tiêu biểu

Bảng sau trình bày các test case tiêu biểu của những chức năng quan trọng, kèm đầu ra thực tế ghi nhận được.

Bảng 4.2. Các test case tiêu biểu

Mã	Mục tiêu test	Dữ liệu đầu vào, các ràng buộc	Đầu ra dự kiến	Đầu ra thực tế	Kết quả
DN-05	Khóa tài khoản khi sai mật khẩu nhiều lần	Sai mật khẩu 5 lần liên tiếp (tối đa 5 lần, khóa 5 phút)	Báo khóa tạm thời; nhập đúng mật khẩu vẫn bị từ chối	Lần sai thứ 5 báo bị khóa tạm thời 5 phút; đăng nhập đúng sau đó vẫn bị từ chối	Pass
DN-12	Chặn chiếm hồ sơ bằng số điện thoại	Đăng ký bằng SĐT đã có hồ sơ, không nhập mã thành viên	Từ chối, hướng dẫn nhập mã thành viên	Từ chối, báo số điện thoại đã có hồ sơ và yêu cầu nhập mã thành viên	Pass
KS-08	Từ chối ảnh bìa sai định dạng	Tệp .pdf	Báo chỉ nhận .jpg, .jpeg, .png, .webp	Báo “Chỉ chấp nhận ảnh .jpg, .jpeg, .png hoặc .webp.”	Pass
KH-07	Bán thẻ lần đầu	Gói “Thường - 1 tháng”: phí 50.000 đ, cọc 100.000 đ	Tổng thu 150.000 đ, 2 biên lai, cọc giữ 100.000 đ	Tổng thu 150.000 đ; biên lai PT000008 (phí thẻ) và PT000009 (cọc); cọc đang giữ 100.000 đ	Pass
MT-01	Cho mượn hợp lệ	Khách có thẻ hiệu lực, 2 mã vạch hợp lệ còn sẵn	Phiếu 2 cuốn, hạn = hôm nay + 14 ngày; 2 bản “Đang mượn”	Tạo phiếu 2 cuốn, hạn trả 02/11/2026 (14 ngày); 2 bản chuyển Đang mượn	Pass
MT-05	Không vượt số sách tối đa	Gói tối đa 3 cuốn, nhập 4 mã cùng lúc	Báo chỉ mượn thêm được 3 cuốn	Báo khách chỉ mượn thêm được 3 cuốn, không tạo phiếu	Pass
MT-10	Chống mượn trùng một bản	Hai yêu cầu đồng thời cùng một mã vạch cho hai khách khác nhau	Chỉ một yêu cầu thành công; không có bản sao nào có hai dòng mượn chưa trả	Một yêu cầu thành công, một yêu cầu báo bản sao đang được mượn	Pass
MT-15	Tính phạt trả trễ	Sách miễn phí thuê, trễ 5 ngày, mức phạt 2.000 đ/ngày	Phạt 10.000 đ; tổng thu 10.000 đ	Phạt 10.000 đ (5 × 2.000), thu 10.000 đ, biên lai PT000021	Pass
MT-18	Trả sách mất và ghi nợ	Chọn Mất, giá đền 80.000 đ, bỏ chọn “Thu tiền ngay”	Khoản đền ở trạng thái “Còn nợ”; bản sao “Mất”; khách bị chặn mượn	Khoản đền 80.000 đ ở trạng thái Còn nợ (PT000018); bản sao Mất; khách bị chặn mượn đến khi thu nợ	Pass

Mã	Mục tiêu test	Dữ liệu đầu vào, các ràng buộc	Đầu ra dự kiến	Đầu ra thực tế	Kết quả
TT-04	Hủy giao dịch có lý do	Hủy khoản đền sách, lý do ≥ 5 ký tự	Chuyển "Đã hủy", hiện lý do; doanh thu giảm	Giao dịch chuyển Đã hủy, hiện lý do và người hủy; doanh thu giảm tương ứng	Pass
TT-07	Doanh thu không gồm tiền cọc	Trong ngày có bán thẻ, trả sách, thu phạt và thu cọc	Doanh thu trên bảng điều khiển khớp tổng các khoản doanh thu, không gồm cọc	Doanh thu hôm nay 320.000 đ khớp tổng tính tay các khoản phí thẻ, phí thuê, phạt, đền; cọc không tính	Pass
WEB-16	Gia hạn bằng AJAX/API	Sách chưa quá hạn, còn lượt gia hạn	Trả 200; hạn trả tăng thêm số ngày của gói	Trả 200; hạn trả 02/11 thành 16/11/2026; số lần gia hạn 1	Pass
WEB-25	Chống CSRF với API	POST gia hạn không có token	Trả 400, không gia hạn	Trả 400, dữ liệu không đổi	Pass
BM-07	Chống XSS	Tên sách chứa thẻ `<script>` và `<img onerror>`	Hiển thị như chữ, không chạy script	Được mã hóa trên mọi trang (chi tiết, danh sách, quản trị, trang chủ); không script nào chạy	Pass

4.3. Kết quả test pass/fail, đề xuất và mô tả quá trình fix lỗi

Kết quả tổng hợp

Sau đợt kiểm thử ngày 19/10/2026, trong 115 test case có **107 test case Pass (93,0%)**, **1 test case Fail** và **7 test case chưa thực hiện** (chi tiết bên dưới). Trong 73 test case ưu tiên Cao có 71 test case Pass; hai test case Cao còn lại (WEB-15, BM-06) mới kiểm tra được một phần. Không phát hiện lỗi nghiêm trọng ở các nghiệp vụ cốt lõi (mượn, trả, gia hạn, tính phí, thu tiền, hoàn cọc) và ở các kiểm tra bảo mật (phân quyền, CSRF, XSS, SQL injection, truy cập chéo dữ liệu). Các lỗi tìm thấy chủ yếu liên quan đến ngôn ngữ của thông báo.

Lỗi phát hiện trong đợt kiểm thử và đề xuất sửa

Bảng 4.3. Lỗi phát hiện khi kiểm thử và đề xuất sửa

Mã test	Mô tả lỗi	Mức độ	Đề xuất sửa	Tình trạng
DN-16 (Fail)	Đăng ký bằng email đã tồn tại bị từ chối nhưng thông báo bằng tiếng Anh và lặp hai lần: "Username ... is already taken. Email ... is already taken."	Trung bình	Kiểm tra email bằng `FindByEmailAsync` trước khi tạo tài khoản và báo một lỗi tiếng Việt duy nhất; hoặc dịch các lỗi Identity bằng lớp kế thừa `IdentityErrorDescriber`.	Chưa sửa, ghi nhận ở mục 5.1
KH-02 (Pass, cần sửa)	Nhập số không hợp lệ ở form gói thẻ bị từ chối nhưng thông báo `[Range]` mặc định bằng tiếng Anh ("The field ... must be between ...").	Thấp	Đặt `ErrorMessage` tiếng Việt (hoặc khóa tài nguyên) cho các thuộc tính `[Range]` ở ViewModel gói thẻ và sách.	Chưa sửa

Mã test	Mô tả lỗi	Mức độ	Đề xuất sửa	Tình trạng
DN-09, DN-10	Trang "Access denied" khi truy cập sai quyền, và hai trang Hồ sơ, Đổi mật khẩu của Identity, vẫn hiển thị tiếng Anh.	Thấp	Tạo trang từ chối truy cập tiếng Việt và đặt `AccessDeniedPath` trỏ tới trang đó; dịch hoặc thay hai trang Identity bằng trang trong khu khách hàng.	Chưa sửa, ghi nhận ở mục 5.1
KS-13 (Pass, cần sửa nhỏ)	Giao diện đã khóa việc đổi trạng thái bản sao đang mượn, nhưng nếu ép gửi yêu cầu thì máy chủ báo "Đã cập nhật bản sao" dù trạng thái không đổi (dữ liệu vẫn đúng).	Thấp	Trong xử lý POST của `BookCopiesController.Edit`, nếu bản sao có dòng mượn chưa trả thì trả lỗi "Bản sao đang được mượn, hãy trả sách trước" thay cho thông báo thành công.	Chưa sửa

Test case chưa thực hiện

Bảng 4.4. Các test case chưa thực hiện

Mã test	Nội dung	Lý do chưa thực hiện
KS-14, KH-03	Xóa sách còn bản sao; xóa gói thẻ đã bán	Thao tác xóa dữ liệu, chưa được thực hiện trong đợt này (KS-03 xóa tác giả còn sách đã thực hiện và Pass).
WEB-07	Cookie "sách xem gần đây" bị sửa giá trị	Cookie HttpOnly, cần sửa bằng công cụ DevTools của trình duyệt.
WEB-10	Session mất khi đóng trình duyệt	Lần thử đầu giỏ vẫn còn do trình duyệt khôi phục cookie phiên; cần thử lại bằng cửa sổ ẩn danh.
WEB-15	Hiển thị sách quá hạn ở phía khách hàng	Đã kiểm tra danh sách sách đang mượn; chưa kiểm tra trường hợp quá hạn từ phía khách.
MT-16	Phạt không vượt giá đền	Mới kiểm tra ca trễ 100 ngày (phạt 200.000 đ, nhỏ hơn giá đền 320.000 đ); chưa có ca phạt vượt giá đền.
BM-06	Cờ của cookie	Đã xác nhận cookie đăng nhập và session là HttpOnly; chưa xác nhận cờ Secure và SameSite.

Lỗi gặp trong quá trình phát triển và cách khắc phục

Bảng sau ghi các lỗi và vấn đề đã gặp khi lập trình và chạy thử trước đợt kiểm thử chính, cùng nguyên nhân và cách khắc phục. Mỗi lỗi sau khi sửa đều được chạy lại test case liên quan.

Bảng 4.5. Các lỗi đã phát hiện và cách khắc phục

Lỗi, vấn đề	Nguyên nhân	Cách khắc phục
Ứng dụng báo "không kết nối được database" khi khởi động.	Tên database trong chuỗi kết nối khác tên database thực tế tạo bằng script.	Đồng bộ tên trong `appsettings.json`; thêm kiểm tra kết nối lúc khởi động với thông báo rõ ràng.

Lỗi, vấn đề	Nguyên nhân	Cách khắc phục
Lỗi biên dịch: không tìm thấy `Microsoft.EntityFrameworkCore`, `IdentityDbContext`, `AddDefaultIdentity`.	Dự án tạo ở chế độ không có xác thực nên thiếu các gói NuGet.	Cài đủ bốn gói bản 10.x (EF Core SqlServer, Tools, Identity.EntityFrameworkCore, Identity.UI).
Trang đăng nhập trả 404; sau đó lỗi "No service for type Loc".	`Program.cs` chưa có cấu hình Identity, Razor Pages hoặc đăng ký dịch vụ mới.	Thay `Program.cs` đầy đủ, build và chạy lại; bổ sung kiểm tra cấu hình sau mỗi lần thêm tính năng.
Giao diện công khai mất theme: chữ menu trắng trên nền trắng.	Tệp `portal.css` chưa được nạp (chưa đặt đúng `wwwroot/css` hoặc chưa chạy lại ứng dụng).	Đặt tệp đúng vị trí, build lại, tải lại trang bằng Ctrl + F5.
Ảnh bìa tải lên không hiển thị.	`MapStaticAssets` chỉ phục vụ tệp có sẵn lúc build, không phục vụ tệp thêm khi đang chạy.	Thêm `app.UseStaticFiles()` vào pipeline.
Doanh thu bị tính cả tiền cọc, số liệu sai bản chất.	Cộng mọi giao dịch đã thu mà không phân loại.	Chỉ tính phí thẻ, phí thuê, phạt, đền vào doanh thu; thêm thẻ "Tiền cọc đang giữ".
Có thể chiếm hồ sơ khách khác chỉ bằng biết số điện thoại.	Liên kết hồ sơ khi đăng ký chỉ so khớp số điện thoại.	Bắt buộc khớp cả mã thành viên và số điện thoại; chỉ biết số điện thoại thì từ chối.
Đăng nhập sai nhiều lần không bị khóa.	Trang đăng nhập mặc định của Identity gọi `lockoutOnFailure: false`.	Viết lại trang đăng nhập với `lockoutOnFailure: true`, cấu hình 5 lần, 5 phút.
API trả trang đăng nhập (mã 302) khi chưa đăng nhập.	Cookie authentication mặc định chuyển hướng.	Cấu hình sự kiện `OnRedirectToLogin` và `OnRedirectToAccessDenied` trả 401 và 403 cho địa chỉ `/api`.
Gia hạn bằng AJAX bị 400.	Yêu cầu POST không mang token chống CSRF.	Cấu hình `AddAntiforgery` nhận header `RequestVerificationToken` và gửi token từ trang.
Logic tìm kiếm viết lặp ở trang web và API, dễ lệch kết quả.	Hai nơi cùng cài đặt bộ lọc.	Gom vào phương thức `BookQueries.Search` dùng chung.

Nhận xét kết quả kiểm thử

Hệ thống đáp ứng tốt các yêu cầu chức năng: 107/115 test case Pass, trong đó toàn bộ nhóm thu tiền và báo cáo (13/13) đạt, và các nghiệp vụ phức tạp như chống mượn trùng khi thao tác đồng thời, tính phí và phạt, ghi nợ, hoàn cọc đều cho kết quả đúng. Các lỗi còn lại tập trung ở việc bản địa hóa thông báo của các thành phần mặc định (Identity, Data Annotations), có mức độ thấp và không ảnh hưởng đến tính đúng đắn của dữ liệu. Các test chưa thực hiện chủ yếu cần thao tác tay trên trình duyệt hoặc dữ liệu đặc biệt, sẽ được bổ sung khi có điều kiện.

CHƯƠNG 5. KẾT LUẬN

5.1. Kết quả đạt được

Đề tài đã xây dựng được một website quản lý thư viện hoàn chỉnh, chạy được trọn vẹn quy trình từ nhập sách, bán thẻ, mượn, trả, gia hạn, thu tiền đến báo cáo, đồng thời cung cấp cổng tự phục vụ cho khách hàng. Kết quả cụ thể:

- **Hệ thống hai vai trò** (Admin, User) cùng phần công khai, với khu quản trị tách riêng bằng Area: 12 controller quản trị, 6 controller công khai và khách hàng, 3 controller REST API.
- **Cơ sở dữ liệu 17 bảng** (10 bảng nghiệp vụ) có script tạo tự động, dữ liệu mẫu, khóa duy nhất, chỉ mục lọc chống mượn trùng, kiểm soát đồng thời.
- **Nghiệp vụ trọng tâm** được cài đặt đầy đủ với kiểm tra điều kiện tự động: mượn, trả, gia hạn, phạt, đền, ghi nợ, thu nợ, bán thẻ, cọc, hoàn cọc, hủy giao dịch, 5 báo cáo, xuất CSV.
- **Đáp ứng đầy đủ các yêu cầu kỹ thuật của đề**: template tùy biến, Responsive, Paging, Filtering, AJAX, CRUD, session, cookie, annotation, REST API, bảo mật và quốc tế hóa (bảng đối chiếu ở mục 1.2).
- **115 test case** được xây dựng và chạy kiểm thử: 107 Pass, 1 Fail, 7 chưa thực hiện; không có lỗi nghiêm trọng ở nghiệp vụ và bảo mật (xem mục 4.3).

Hạn chế còn tồn tại

- Khu quản trị mới chỉ có tiếng Việt; một số thông báo nghiệp vụ trong khu quản trị chưa dịch.
- Một số thông báo của thành phần mặc định còn bằng tiếng Anh: trang từ chối truy cập, trang Hồ sơ và Đổi mật khẩu của Identity, thông báo `[Range]` ở form gói thẻ, lỗi trùng email khi đăng ký (xem mục 4.3).
- Chưa có chức năng đặt giữ sách trước, thanh toán trực tuyến, gửi email hoặc SMS nhắc hạn; tài khoản mới chưa được xác thực qua email.
- Chỉ có hai vai trò; chưa phân biệt quyền giữa chủ và nhân viên, chưa có nhật ký thao tác.
- Kiểm thử mới ở mức thủ công; chưa có kiểm thử đơn vị và tích hợp tự động.
- Chỉ hỗ trợ một cơ sở, sách in; chưa tối ưu cho khối lượng dữ liệu rất lớn (một số báo cáo tổng hợp trong bộ nhớ).

5.2. Bài học được rút ra

- **Thiết kế dữ liệu đúng từ đầu tiết kiệm nhiều công sau này**: tách đầu sách và bản sao, tách hồ sơ khách và tài khoản, tách khoản phải thu và khoản đã thu. Không lưu dữ liệu dẫn xuất (quá hạn, số còn lại) giúp dữ liệu luôn nhất quán.
- **Đặt quy tắc nghiệp vụ ở một nơi** (`LoanRules`) giúp trang quản trị, trang khách hàng và API không lệch nhau; sửa một chỗ, ba nơi cùng đúng.
- **Bảo mật phải làm ở máy chủ**: không tin số tiền, mã khách, kết quả kiểm tra từ trình duyệt; kiểm tra quyền sở hữu dữ liệu ở mỗi yêu cầu; dùng ràng buộc của cơ sở dữ liệu làm lớp bảo vệ cuối.

- **Làm theo từng vòng nhỏ và chạy thử sau mỗi vòng** giúp phát hiện lỗi cấu hình (chuỗi kết nối, gói NuGet, `Program.cs`) sớm; nhiều lỗi mất thời gian nhất lại là lỗi môi trường chứ không phải lỗi logic.
- **Viết test case sớm** buộc phải nghĩ về các trường hợp biên (hết lượt gia hạn, sách quá hạn, hai người thao tác cùng lúc) và thường phát hiện lỗ hổng thiết kế, ví dụ lỗi chiếm hồ sơ bằng số điện thoại.
- **Ước lượng thời gian và cắt phạm vi** hợp lý: rút số bảng từ 21 xuống 10 bảng nghiệp vụ và để các chức năng phụ vào hướng phát triển giúp hoàn thành các yêu cầu bắt buộc đúng hạn.

5.3. Đề xuất phương hướng phát triển

Bảng 5.1. Đề xuất hướng phát triển

Hướng	Nội dung
Nghiệp vụ	Đặt giữ sách khi hết bản (xếp hàng chờ, giữ 2 ngày); nhắc hạn trả bằng email hoặc SMS; mượn liên thư viện; sách điện tử.
Thanh toán	Tích hợp cổng thanh toán trực tuyến (thanh toán thẻ, gia hạn thẻ trên web); xuất hóa đơn.
Phân quyền, kiểm soát	Tách quyền chủ và nhân viên; nhật ký thao tác (ai sửa gì, lúc nào); xác thực email, xác thực hai lớp.
Công nghệ	Quét mã vạch bằng thiết bị hoặc camera; ứng dụng di động dùng chung REST API; tài liệu API bằng OpenAPI/Swagger; đóng gói Docker và triển khai lên đám mây.
Chất lượng	Viết kiểm thử đơn vị và tích hợp tự động (xUnit); đo hiệu năng và bổ sung chỉ mục; xử lý báo cáo trực tiếp trên cơ sở dữ liệu khi dữ liệu lớn.
Trải nghiệm	Quốc tế hóa cả khu quản trị; gợi ý sách theo lịch sử mượn; đánh giá, bình luận sách.

Tài liệu tham khảo

[1] Microsoft. ASP.NET Core documentation. https://learn.microsoft.com/aspnet/core

[2] Microsoft. Entity Framework Core documentation. https://learn.microsoft.com/ef/core

[3] Microsoft. Globalization and localization in ASP.NET Core. https://learn.microsoft.com/aspnet/core/fundamentals/localization

[4] Microsoft. Introduction to Identity on ASP.NET Core. https://learn.microsoft.com/aspnet/core/security/authentication/identity

[5] Microsoft. Prevent Cross-Site Request Forgery (XSRF/CSRF) attacks in ASP.NET Core. https://learn.microsoft.com/aspnet/core/security/anti-request-forgery

[6] Bootstrap. Bootstrap 5 documentation. https://getbootstrap.com/docs/5.3

[7] jQuery. jQuery API documentation. https://api.jquery.com

[8] IETF. RFC 7807: Problem Details for HTTP APIs. https://www.rfc-editor.org/rfc/rfc7807